

ISO 27001:2022

la guía definitiva



*Descubre las Estrategias Clave para
una Implementación Exitosa*

César Viteri P.

VITERI César

**ISO/IEC 27001:2022
LA GUÍA DEFINITIVA**

Sobre el autor

César Viteri es un profesional con una amplia experiencia en Seguridad y Privacidad de la Información. Después de recibir su diplomado en Auditoría Informática y Forense, ha asumido varios roles críticos en el campo de la ciberseguridad, incluyendo el de Analista de Seguridad Informática y Oficial de Cumplimiento SGSI.

En su trayectoria, César ha liderado proyectos exitosos de implementación y certificación de normas ISO/IEC 27001 e ISO/IEC 37001, destacándose por su enfoque proactivo y su habilidad para administrar riesgos. Su contribución al campo de la ciberseguridad va más allá de su labor profesional, pues es autor del libro "ISO/IEC 27001:2022 un enfoque práctico", una guía útil y práctica para aquellos interesados en la seguridad de la información.

Bajo la filosofía de que "la defensa proactiva de la información genera seguridad a largo plazo", el autor busca constantemente promover la importancia de la seguridad de la información, no sólo como un aspecto técnico, sino como un componente fundamental para el éxito y la integridad de cualquier organización. Su experiencia y compromiso ISO/IEC lo convierten en un verdadero líder en el campo de la seguridad y privacidad de la información.

Prólogo

La seguridad de la información se ha convertido en uno de los temas más críticos en la sociedad digital de hoy. A medida que la cantidad de datos generados y almacenados crece exponencialmente, también lo hace la necesidad de proteger esa información de las amenazas, tanto internas como externas. Por este motivo, la implementación de un Sistema de Gestión de Seguridad de la Información (SGSI) se ha vuelto esencial para cualquier organización, independientemente de su tamaño o sector.

Este ha sido uno de los motivos uno de los motivos que me han impulsado a escribir "ISO/IEC 27001:2022 LA GUÍA DEFINITIVA". Esta guía tiene como finalidad proporcionar a los lectores un recurso completo y comprensible para entender y aplicar norma ISO/IEC 27001 versión 2022, en su propia organización. La implementación de esta norma puede ser un desafío; especialmente para aquellas organizaciones que no tienen experiencia previa en la gestión de la seguridad de la información. Sin embargo, con las orientaciones correctas, se puede convertir en un proceso manejable y en última instancia, en una inversión valiosa para cualquier empresa.

Esta guía tiene la intención de desmitificar la complejidad de la implementación de una norma de alto nivel, como lo es la ISO/IEC 27001:2022 y, convertirla en un camino claro y factible. Aquí, he procurado destilar mi propia experiencia y conocimientos en la materia, buscando siempre presentar la información de manera accesible para todos, ya sean principiantes en el tema o profesionales experimentados que buscan mejorar sus habilidades.

Este libro, está diseñado para servir como un recurso de consulta a lo largo de todo el proceso de implementación. En lugar de ser un manual teórico, se ha diseñado para ser un compañero práctico que proporciona consejos útiles, ejemplos de la vida real y recomendaciones concretas en cada paso del camino.

Al final del día, el objetivo de este libro es ayudar a las organizaciones a construir un entorno seguro en el que puedan operar con confianza, sabiendo que están haciendo todo lo posible para proteger la información que es vital para su éxito.

La seguridad de la información es un viaje, no un destino. " ISO/IEC 27001:2022 LA GUÍA DEFINITIVA " está diseñado para ser un aliado en ese viaje, proporcionando las herramientas y el conocimiento necesarios para navegar por el mundo de la seguridad de la información con confianza y éxito.

Espero que encuentres este recurso útil y edificante en tu camino hacia la implementación de ISO/IEC 27001.

¡Bienvenido!

A mi querido abuelito César,
cuyo amor y enseñanzas
siempre guiaron mi camino. Y
a mi esposa, mi mejor amiga
y compañera incondicional.

Contenido

1. Introducción a la Norma ISO/IEC 27001:2022
 - 1.1. Antecedentes y evolución de la norma
 - 1.2. Relación con la familia ISO/IEC 27000
 - 1.3. Propósito y alcance de la norma
 - 1.3.1. Propósito de la Norma ISO/IEC 27001
 - 1.3.2. Alcance de la Norma ISO/IEC 27001:
2. Conceptos fundamentales de seguridad de la información
 - 2.1. Principios de seguridad de la información
 - 2.2. Evaluación y gestión de riesgos
 - 2.3. Ciclo de vida de la seguridad de la información
3. Requisitos generales de la Norma ISO/IEC 27001:2022
 - 3.1. Política de seguridad de la información
 - 3.2. Responsabilidades y roles
4. Evaluación de riesgos y tratamiento
 - 4.1. Metodologías de evaluación de riesgos
 - 4.1.1. Identificación y clasificación de activos
 - 4.1.2. Identificación y selección de amenazas
 - 4.1.3. Identificación de vulnerabilidades y salvaguardas
 - 4.1.4. Evaluación de Riesgo Inherente
 - 4.1.5. Identificación y Valoración de controles existentes
 - 4.1.6. Evaluación de la Efectividad de los Controles
 - 4.1.7. Evaluación y calificación del Riesgo Residual
 - 4.2. Criterio de aceptación de Riesgos
 - 4.3. Declaración de aplicabilidad
5. Temas de seguridad de la información según ISO/IEC 27002:2022
6. Monitoreo, medición, análisis y evaluación
 - 6.1. Monitoreo y medición de la efectividad de los controles
 - 6.2. Auditorías internas y externas
 - 6.3. Evaluación y revisión de riesgos
 - 6.4. Mejora continua
7. Mantenimiento y mejora continua del SGSI
 - 7.1. Revisión y actualización de la política de seguridad de la información

[7.2. Revisión y ajuste de los controles de seguridad](#)

[7.3. Capacitación y concientización en seguridad de la información](#)

[7.4. Evaluación del desempeño del SGSI](#)

[8. Preparación y obtención de la certificación ISO/IEC 27001](#)

[8.1. Entendiendo los requisitos de la certificación ISO/IEC 27001](#)

[8.2. Selección de un organismo de certificación](#)

[8.3. Preparación para la auditoría de certificación](#)

[8.4. Mantenimiento y renovación de la certificación ISO/IEC 27001](#)

[9. Casos de éxito y de fracaso](#)

[9.1. Análisis de casos de éxito](#)

[9.2. Estudio de casos de fracaso](#)

[10. Recursos para la implementación de la norma ISO/IEC 27001:2022](#)

[10.1. Plantillas y documentos de referencia](#)

[10.2. Software y herramientas de gestión de riesgos](#)

[10.3. Fuentes de información y actualización sobre seguridad de la información](#)

[ANEXOS](#)

[ANEXO A – POLÍTICA DE SEGURIDAD DE LA INFORMACIÓN](#)

[ANEXO B – DECLARACIÓN DE APLICABILIDAD](#)

[ANEXO C – GESTIÓN DE RIESGOS DE SEGURIDAD DE LA INFORMACIÓN](#)

[Identificación y clasificación de Activos](#)

[Identificación y selección de amenazas](#)

[Identificación de vulnerabilidades](#)

[Evaluación de Riesgo Inherente](#)

[Identificación y Valoración de controles existentes](#)

[Evaluación de la efectividad de los controles](#)

[Evaluación y calificación de Riesgo Residual](#)

[ANEXO D – PLAN DE TRATAMIENTO DE RIESGOS](#)

[ANEXO E - OBJETIVOS DE SEGURIDAD DE LA INFORMACIÓN](#)

[ANEXO F – POLÍTICA DE GESTIÓN DE ACCESO](#)

[ANEXO G – CLASIFICACIÓN DE LA INFORMACIÓN](#)

[ANEXO H – GESTIÓN DE INCIDENTES DE SI](#)

[ANEXO I – REVISIÓN POR LA DIRECCIÓN](#)

1. Introducción a la Norma ISO/IEC 27001:2022

1.1. Antecedentes y evolución de la norma

La norma ISO/IEC 27001 es parte de la familia ISO/IEC 27000 de normas de sistemas de gestión de seguridad de la información (SGSI). En un principio, se publicó la norma británica BS-7799^[1], la cual comprendía un conjunto de buenas prácticas de seguridad de la información adaptadas a la realidad británica de la época. Ya en 2005 se publica la norma ISO/IEC ^[2]17799, la cual toma y amplía la norma británica BS 7799. Luego, en el año 2013, se publica la versión ISO/IEC 27001:2013, que fue ampliamente adoptada en todo el mundo. La versión actual, ISO/IEC 27001:2022, ha sido actualizada para abordar las cambiantes necesidades de seguridad de la información en el contexto moderno.

A continuación, se muestra la evolución de la norma a través de los años:

Norma	Publicación	Dominios	Controles
ISO/IEC 27001:2005	2005	11	133
ISO/IEC 27001:2013	2013	14	114
ISO/IEC 27001:2017	2017	14	114
ISO/IEC 27001:2022	2022	4 ^[3]	93

Tabla 1: Norma ISO/IEC 27001

1.2. Relación con la familia ISO/IEC 27000

La familia ISO/IEC 27000 comprende un conjunto de normas internacionales que abordan diferentes aspectos de la seguridad de la información.

A continuación, se listan algunas de las normas de la familia a la ISO/IEC 27000:

ISO/IEC	Descripción
27000	Visión general y vocabulario de la familia ISO/IEC 27001.
27001	Requisitos para un sistema de gestión de seguridad de la información (SGSI).
27002	Código de buenas prácticas para la gestión de la seguridad de la información

27003	Guía para la implementación de un SGSI.
27004	Guía para la medición y evaluación de la gestión de la seguridad de la información.
27005	Guía para la gestión de riesgos de seguridad de la información.
27006	Requisitos para la certificación de un SGSI por parte de un organismo de certificación.
27007	Guía para la auditoría de un SGSI.
27010	Guía para la gestión de la seguridad de la información en las relaciones interorganizacionales.
27011	Guía para la gestión de la seguridad de la información en las telecomunicaciones.
27013	Guía para la integración de la gestión de la seguridad de la información en los procesos de gestión del negocio.
27014	Guía para la gobernanza de la seguridad de la información.
27017	Directrices para la seguridad de la información en la nube.
27018	Directrices para la protección de la información personal identificable (PII) en la nube.
27019	Guía para la gestión de la seguridad de la información en el sector energético.
27031	Directrices para la continuidad del negocio de tecnologías de la información y la comunicación (TIC).
27032	Directrices para la ciberseguridad.
27799	Directrices para la gestión de la seguridad de la información en la atención sanitaria.

Tabla 2: Familia ISO/IEC 27001

De esta familia destaca la norma ISO/IEC 27001^[4], la cual es la base para establecer, implementar, mantener y mejorar un SGSI. Esta norma proporciona directrices detalladas y buenas prácticas para la implementación de controles de seguridad de la información en apoyo de un SGSI.

No podemos dejar de mencionar a la norma ISO/IEC 27002, que comprende los controles de seguridad de la información y que conforman el Anexo A de la norma certificable y a la norma ISO/IEC 27005 que es una guía para la gestión de riesgos de seguridad de la información.

En el presente libro se mencionarán únicamente, las normas ISO/IEC 27001, ISO/IEC 27002 y ISO/IEC 27005.

1.3. Propósito y alcance de la norma

1.3.1. Propósito de la Norma ISO/IEC 27001

El propósito principal de la norma ISO/IEC 27001 es ayudar a las organizaciones a establecer y mantener un sistema de gestión de la seguridad de la información. A través de este marco, las organizaciones pueden identificar, gestionar y reducir los riesgos a los que se enfrenta su información. Esto incluye la protección de los datos corporativos, la información del cliente y otras formas de propiedad intelectual.

1.3.2. Alcance de la Norma ISO/IEC 27001:

El alcance de la norma ISO/IEC 27001 es amplio y adaptable a organizaciones de cualquier tamaño o industria. La norma se aplica a todas las formas de información (papel, digital, tangible, etc.) y a todos los sistemas de información relacionados con el procesamiento, almacenamiento, transmisión y recuperación de información.

Un aspecto importante del alcance de la norma es que debe ser definido por la organización misma. Esto significa que la organización necesita determinar los límites y la aplicabilidad del SGSI para lograr los objetivos de la seguridad de la información.

El alcance de la norma cubre aspectos técnicos (como la infraestructura de TI, las redes, los sistemas, etc.), aspectos humanos (como la conciencia, el comportamiento, las competencias, etc.) y aspectos organizativos (como las políticas, los procedimientos, la estructura organizativa, etc.).

2. Conceptos fundamentales de seguridad de la información

2.1. Principios de seguridad de la información

Los principios fundamentales de la seguridad de la información son conocidos como la Tríada de la **CIA**: *Confidencialidad*, *Integridad* y *Disponibilidad*. Estos son los pilares en los que se basa la seguridad de la información.

- **Confidencialidad:** Este principio se refiere a la protección que se debe proporcionar a la información para que esta no sea accesible por personas no autorizadas. Se trata de asegurar que solo aquellos que tienen el derecho y la necesidad de acceder a la información puedan hacerlo. Esto puede lograrse mediante una combinación de políticas de control de acceso, cifrado y conciencia y formación de los empleados.
- **Integridad:** Este principio se refiere a la protección que se debe proporcionar a la información de ser modificada de manera no autorizada o no intencionada. Asegura que la información es exacta y completa durante su ciclo de vida. Para asegurar la integridad, se pueden utilizar controles como el registro y monitorización de actividades, procedimientos de cambio estrictos y sistemas de backup y recuperación de datos.
- **Disponibilidad:** Este principio se refiere a la protección que se debe proporcionar a la información para que esta esté disponible cuando se lo necesite. Esto puede implicar la implementación de medidas de redundancia, la planificación de la capacidad, y la implementación de procedimientos de respaldo y recuperación. También puede incluir medidas para resistir y recuperarse de los incidentes de seguridad, como ataques de denegación de servicio.

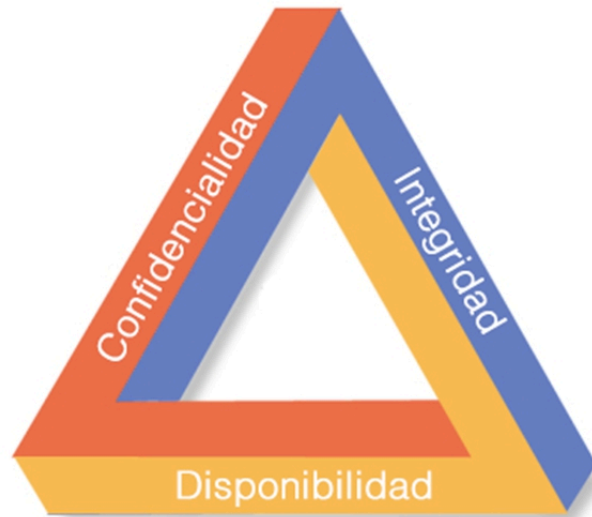


Gráfico 1: Triángulo CID

2.2. Evaluación y gestión de riesgos

La evaluación y gestión de riesgos son procesos esenciales en la seguridad de la información. La evaluación de riesgos implica identificar, analizar y evaluar los riesgos a los que están expuestos los activos de información de una organización. La gestión de riesgos implica tomar decisiones sobre cómo abordar y mitigar estos riesgos mediante la implementación de controles adecuados. Esto incluye el monitoreo y revisión de riesgos y controles de forma regular para garantizar su eficacia.

Las evaluaciones de riesgo son fundamentales para identificar las amenazas y vulnerabilidades que pueden afectar la seguridad de la información en una organización. Los riesgos pueden variar en severidad y en el impacto que pueden tener en la organización. Sin una adecuada evaluación de riesgos, la organización puede no estar preparada para afrontar estas amenazas, lo que puede resultar en pérdidas financieras, daños a la reputación y violaciones de la ley.

La norma ISO/IEC 27001 no prescribe un método específico para realizar la evaluación de riesgos, ya que este puede variar en función de la naturaleza de la organización. Sin embargo, sí establece ciertos requerimientos que se deben cumplir:

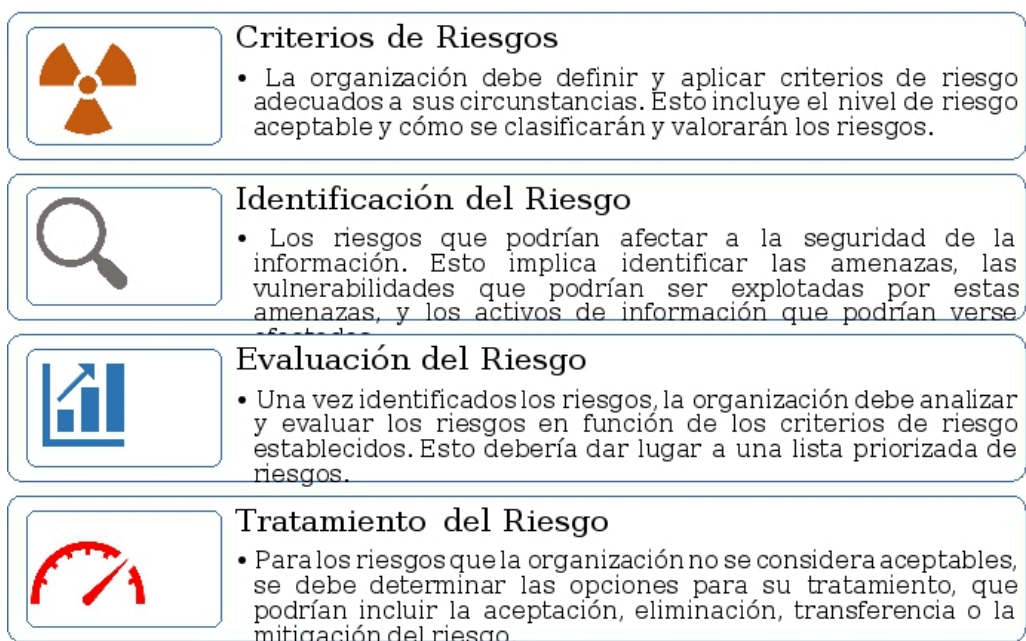


Gráfico 2: Evaluación y gestión de Riesgos

Además, la norma requiere que la evaluación de riesgos se realice a intervalos planificados o cuando se produzcan cambios significativos. Esto puede incluir cambios en la organización, su tecnología, su entorno legal y regulatorio, entre otros. La frecuencia exacta de las evaluaciones de riesgo dependerá de la naturaleza de la organización y su nivel de riesgo, pero una buena práctica general es realizarla al menos una vez al año.

Como dato adicional, es importante recalcar que la gestión de riesgos no es un proceso único, sino que es un proceso continuo que forma parte de la operación normal de la organización.

Muchas organizaciones toman como punto de partida para el análisis, valoración y tratamiento de riesgos a la norma ISO/IEC 27005:2022; sin embargo, depende de cada organización el escogimiento de la metodología mas adecuada y de los criterios utilizados para este análisis.

2.3. Ciclo de vida de la seguridad de la información

El ciclo de vida de la seguridad de la información consta de varias etapas, que incluyen la identificación de activos y riesgos, la selección e implementación de controles, el monitoreo y medición de la eficacia de los controles, y la mejora continua. Este enfoque cíclico garantiza que la seguridad de la información se mantenga en línea con las necesidades cambiantes de la organización y el entorno de amenazas.

La Norma ISO/IEC 27001 proporciona un marco para establecer, implementar, mantener y mejorar continuamente un Sistema de Gestión de la Seguridad de la Información (SGSI), que se basa en el modelo Planificar-Hacer-Verificar-Actuar (PDCA).

- **Planificar (Plan):** Este es el primer paso, en el que se realiza una evaluación de riesgos y se establecen los objetivos de seguridad de la información. Involucra la identificación y evaluación de los riesgos para la seguridad de la información, y la determinación de los controles necesarios para gestionar dichos riesgos. Se desarrolla el alcance del SGSI, y se define una política de seguridad de la información que establece la dirección de la organización en términos de seguridad.
- **Hacer (Do):** Aquí se implementan y operan los controles, las políticas y los procedimientos que se han identificado y planeado en la etapa anterior. Esto puede implicar la implementación de cambios tecnológicos, como nuevas herramientas de seguridad, así como cambios en los procesos y la capacitación del personal.
- **Verificar (Check):** En esta etapa, se monitorea y revisa regularmente el SGSI para asegurarse de que esté funcionando como se esperaba. Esto puede implicar auditorías internas y externas, así como el monitoreo continuo de los incidentes de seguridad y el rendimiento de los controles.
- **Actuar (Act):** Basándose en los resultados de la etapa de Verificación, se toman medidas para mejorar continuamente el rendimiento del SGSI. Esto puede implicar la revisión y modificación de los controles, políticas y procedimientos, y la implementación de nuevas medidas de seguridad si es necesario.



Gráfico 3: Ciclo PHVA para un SGSI

Estos cuatro pasos forman un ciclo continuo. Después de la etapa de Actuar, la organización vuelve a la etapa de Planificar, donde puede reevaluar sus riesgos y modificar su SGSI en consecuencia. De esta manera, la seguridad de la información se gestiona como un proceso en evolución, que se adapta a los cambios en el entorno de la organización y en la propia organización.

3. Requisitos generales de la Norma ISO/IEC 27001:2022

3.1. Política de seguridad de la información

La política de seguridad de la información es un documento de alto nivel que establece los objetivos y principios de seguridad de la información en una organización. Es la base para implementar y mantener un SGSI. La política debe estar alineada con los objetivos y metas de la organización, y debe ser revisada y actualizada periódicamente para mantener su relevancia y eficacia.

A continuación, se detallan algunos de los requisitos mínimos para una efectiva Política de Seguridad de la Información según esta norma:

- **Establecimiento de la Política:** Debe existir una política de seguridad de la información documentada que se apruebe por la alta dirección. Esta política debe ser consistente con los objetivos de negocio y la dirección estratégica de la organización.
- **Alcance de la Política:** Debe estar claramente definido el alcance de la política de seguridad de la información. Esta puede aplicar a varios procesos organizacionales o, a toda la organización y a todos los tipos de información (por ejemplo, digital, física, verbal).
- **Compromiso de la Alta Dirección:** La alta dirección debe demostrar su apoyo y Compromiso con la seguridad de la información mediante la asignación de roles y responsabilidades adecuados.
- **Revisión de la Política:** La política de seguridad de la información debe ser revisada a intervalos regulares o cuando ocurren cambios significativos para asegurar su efectividad y adecuación continua.
- **Comunicación de la Política:** La política de seguridad de la información debe ser comunicada a todas las partes interesadas (empleados, proveedores, clientes, etc.) y estar disponible para su consulta cuando sea necesario.
- **Objetivos de la Política:** Deben establecerse objetivos ^[5] claros y medibles para la seguridad de la información que se alineen con la

política y sean coherentes con los objetivos de negocio de la organización.

- **Conformidad con la Legislación:** La política debe cumplir con los requisitos legales^[6], reglamentarios y contractuales aplicables.
- **Gestión del Riesgo:** Debe indicarse que la organización llevará a cabo evaluaciones de riesgos de seguridad de la información de forma regular, implementando medidas de mitigación acordes a la naturaleza y escala de las operaciones.

3.2. Responsabilidades y roles

La asignación de responsabilidades y roles es un aspecto fundamental en la gestión de la seguridad de la información. Esta práctica implica definir quién será responsable de qué tareas, qué decisiones pueden tomar y qué responsabilidades tienen en relación con la protección de los activos de información de una organización. La importancia de esta tarea radica en garantizar que todos los aspectos de la seguridad de la información estén adecuadamente cubiertos y que no existan áreas sin supervisión ni control.

En este sentido, la norma, establece directrices claras sobre cómo deben definirse y comunicarse estas responsabilidades y roles. De acuerdo con la norma, es esencial que todas las partes interesadas, que pueden incluir a empleados, contratistas, proveedores, socios comerciales y clientes, estén al tanto de sus responsabilidades con respecto a la seguridad de la información.

Un aspecto crucial de estas responsabilidades es la identificación y clasificación de los activos de información. Los activos de información incluyen todo tipo de datos y sistemas de información que una organización posee o utiliza. Alguien debe ser responsable de identificar estos activos y clasificarlos en términos de su valor para la organización y su nivel de sensibilidad y confidencialidad. Esto puede ayudar a determinar qué activos necesitan una protección más rigurosa y cómo deberían protegerse.

Otra responsabilidad importante es la evaluación y el tratamiento de los riesgos. Esto implica identificar las amenazas y vulnerabilidades que pueden afectar a los activos de información de la organización, evaluar el nivel de riesgo que representan y decidir qué medidas se deben tomar para gestionar esos riesgos. Esto puede implicar la implementación de controles de seguridad de la información, como firewalls, sistemas de detección de intrusiones, políticas de acceso y capacitación en seguridad de la información.

Adicionalmente, también debe asignarse la responsabilidad de la implementación y supervisión de estos controles de seguridad. Esta persona o equipo debe garantizar que los controles estén funcionando correctamente, que se mantengan actualizados y que se revisen regularmente para verificar su efectividad. También deben estar preparados para responder a cualquier incidente de seguridad que pueda ocurrir y para realizar los cambios necesarios en los controles de seguridad en función de las lecciones aprendidas de estos incidentes.

4. Evaluación de riesgos y tratamiento

4.1. Metodologías de evaluación de riesgos

La evaluación de riesgos es un componente esencial en la gestión de la seguridad de la información. Existen diversas metodologías de evaluación de riesgos que pueden ser utilizadas para identificar y analizar los riesgos a los que están expuestos los activos de información de una organización.

Los más conocidos métodos de análisis y tratamiento de riesgos de seguridad de la información son la norma ISO/IEC 31000:2018 e ISO/IEC 27005:2022. Ambos son excelentes marcos de referencia para la identificación, análisis y tratamiento de riesgos y, pueden ser usados en casi cualquier contexto.

En este libro, no profundizaremos en ninguna de estas metodologías en particular, más sin embargo, vamos a proponer una metodología híbrida, que usa algunos elementos de ISO/IEC 31000:2018 e ISO/IEC 27005:2022 para cubrir los aspectos más importantes de la identificación, análisis y posterior tratamiento de riesgos de seguridad de la información.

A continuación, se muestra un comparativo entre las dos metodologías más utilizadas para la gestión de riesgos:

Aspecto	ISO/IEC 27005:2022	ISO/IEC 31000:2018
Objetivo	Proporcionar directrices para la gestión de riesgos relacionados con la seguridad de la información.	Proporcionar principios y directrices generales para la gestión de riesgos en cualquier tipo de organización.

Enfoque	Centrado exclusivamente en la gestión de riesgos en el contexto de la seguridad de la información.	Enfoque amplio aplicable a cualquier tipo de riesgo (operacional, financiero, estratégico, etc.).
Ámbito	Principalmente para la seguridad de la información (confidencialidad, integridad y disponibilidad).	Aplicable a todas las áreas de una organización y todo tipo de riesgos.
Norma base	Apoya la implementación de ISO/IEC 27001 y el Sistema de Gestión de Seguridad de la Información (SGSI).	Independiente de otros estándares, pero puede integrarse con sistemas de gestión como ISO 9001, ISO 14001, etc.
Proceso de gestión de riesgos	Define un ciclo específico para identificar, evaluar, tratar y monitorizar los riesgos relacionados con la seguridad de la información.	Sigue un enfoque genérico de gestión de riesgos: identificación, análisis, evaluación, tratamiento, seguimiento y revisión.
Aplicabilidad	Principalmente en sistemas de gestión de seguridad de la información (empresas con certificaciones ISO 27001 o 27002).	Aplicable a cualquier tipo de organización, independientemente de su sector o tamaño.
Evaluación de riesgos	Enfocado en riesgos que comprometen la seguridad de los activos de información.	Se ocupa de la evaluación de cualquier riesgo que pueda afectar a los objetivos organizacionales, abarcando todas las categorías de riesgo.
Tratamiento de riesgos	Proporciona controles específicos relacionados con la seguridad de la información (basados en ISO/IEC 27001 y 27002).	Proporciona un enfoque amplio para el tratamiento de riesgos, permitiendo respuestas como evitar, compartir, reducir o aceptar los riesgos.
Documentación	Extenso en la gestión de riesgos de seguridad de la información con enfoques detallados de análisis de riesgos.	Más genérico en la forma en que documenta la gestión de riesgos, aunque también enfatiza la importancia de mantener registros.
Contexto	Centrado en los riesgos específicos a la seguridad de la información y ciberseguridad.	Contexto más amplio: se refiere a cualquier riesgo organizacional que pueda afectar los objetivos estratégicos.
Interesados	Directamente relacionado con la gestión de riesgos para departamentos de TI, seguridad de la información y cumplimiento.	Aplicable a cualquier parte interesada de la organización, incluyendo la alta dirección, áreas de operaciones, finanzas, etc.
Periodicidad de evaluación	Enfocado en revisiones continuas y actualizaciones específicas al entorno de TI y la seguridad de la información.	Sugiere revisiones regulares como parte de una gestión de riesgos integral, adaptable a la frecuencia requerida por la organización.

Fortalezas	Altamente especializado en seguridad de la información, con guías detalladas para tratar riesgos cibernéticos y de información.	Estandariza la gestión de riesgos en todo tipo de escenarios, proporcionando flexibilidad y un marco escalable para diferentes sectores.
Relación con otras normas	Directamente relacionada con ISO 27001 y otros estándares de la familia ISO 27000.	Puede ser utilizada junto con cualquier otro sistema de gestión de riesgos o normativas específicas del sector.

Tabla 3: Comparativa ISO/IEC 31000:2018 e ISO/IEC 27005:2022

En líneas generales, lo que requiere la norma en una metodología de gestión de Riesgos se puede resumir en lo siguiente:

- Identificación y clasificación de activos
- Identificación y selección de amenazas
- Identificación de vulnerabilidades y salvaguardas
- Evaluación y Calificación de Riesgo Inherente
- Identificación y Valoración de controles existentes
- Evaluación de Riesgo Residual
- Calificación del Riesgo Residual
- Criterio de aceptación de Riesgos
- Acciones por tratamiento de Riesgos no tolerados

4.1.1. Identificación y clasificación de activos

La identificación y clasificación de activos es un paso importante en la evaluación de riesgos. Los activos de información pueden incluir datos, sistemas, aplicaciones, servicios y personas, entre otros. La clasificación de activos implica asignar un valor y nivel de protección a cada activo, basándose en su importancia para la organización y la sensibilidad de la información contenida en él.

Un Activo es un elemento, cosa o entidad que tiene un **valor** real o potencial para la Organización. Este puede ser tangible, intangible, financiero o no financiero.

Los activos se dividen de la siguiente manera:

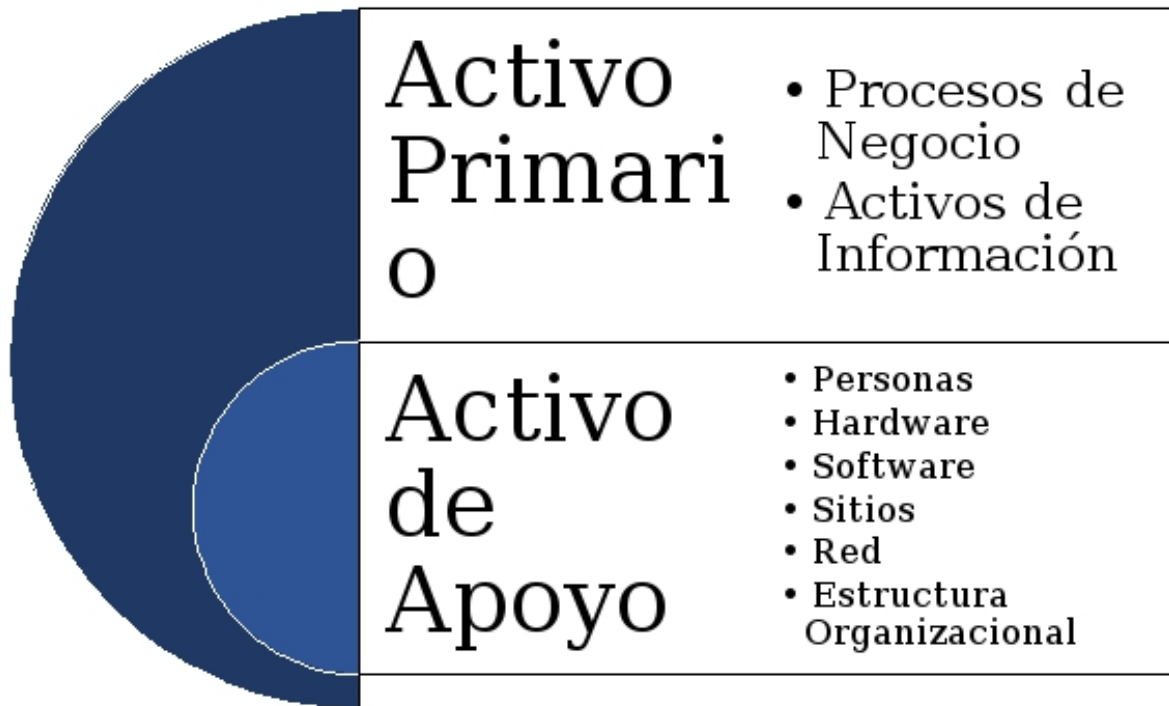


Gráfico 4: Activos de Información

Los **Activos Primarios** se subdividen en Procesos de Negocio y Activos de Información, donde los **Procesos de Negocio** son aquellos procesos clave del negocio. Son la razón de ser de la Organización.

Los **Activos de Información** refieren a las políticas, manuales, instrucciones, procedimientos, etc., que regulan el accionar de la empresa. En otras palabras, los Activos de Información es toda aquella Información que resulta vital para el accionar de la Organización dentro de los ámbitos internos (políticas y regulaciones internas.) y externos (cumplimiento de regulaciones).

Los **Activos de Apoyo** son los entes tangibles o intangibles en donde se encuentra almacenada o gestionada la información. El activo más sobresaliente de estos activos sin duda es el activo **Persona**.

4.1.2. Identificación y selección de amenazas

Para evaluar correctamente el riesgo de un activo, se deben conocer las amenazas que pudiesen estar presentes en el. Cada organización, conoce (al menos de manera empírica) las amenazas que le afectan. Por ejemplo, si la organización se encuentra en una zona sísmica o cerca de zonas donde

regularmente se dan inundaciones, etc. las amenazas pueden derivarse de estas condiciones.

Para ayudar en el proceso de identificación de amenazas, se puede recurrir a la norma ISO/IEC 27005:2022 Anexo C^[2].

Este catálogo cubre la mayoría de las amenazas, a las que se exponen los activos de información. De entre las posibles amenazas que contemplan este catálogo podemos mencionar los más generales:

- Daños físicos a equipos y sistemas: incluye fuego, inundación, terremoto, contaminación, tormentas eléctricas, etc.
- Interrupciones de servicios de utilidad: pérdida de suministro eléctrico, pérdida de suministro de agua, fallo en los sistemas de climatización, etc.
- Fallo en los equipos: fallo en el hardware, fallo en los sistemas de software, fallo en los dispositivos de comunicaciones, etc.
- Fallos en la red: interrupciones de la red, sobrecarga de la red, errores de configuración de red, etc.
- Acciones de terceros: acceso no autorizado, alteración de datos, robo de información, negación de servicio, introducción de software malicioso, etc.
- Errores humanos: errores en el procedimiento, pérdida de datos, mal uso del sistema, etc.

4.1.3. Identificación de vulnerabilidades y salvaguardas

Las **vulnerabilidades** se refieren a las debilidades o fallos en los controles de seguridad que podrían ser explotados por amenazas para comprometer la confidencialidad, integridad o disponibilidad de la información de los activos. Las vulnerabilidades pueden estar presentes en cualquier ámbito de la organización, como por ejemplo la infraestructura tecnológica, los sistemas de software, los procesos operativos o incluso en los factores humanos.

Las vulnerabilidades pueden surgir debido a una variedad de razones, como configuraciones inseguras, falta de parches de seguridad, contraseñas débiles, falta de capacitación en seguridad, fallos en el diseño o implementación de

sistemas, entre otros. Estas vulnerabilidades representan posibles puntos de entrada para que los atacantes exploten y comprometan la seguridad de la información.

Para ayudar en el proceso de identificación de vulnerabilidades, se puede recurrir a la norma ISO/IEC 27005:2022 Anexo D^[8].

Por otro lado, las **salvaguardas** son medidas y controles implementados para mitigar o eliminar las vulnerabilidades y proteger los activos de información de una organización. Estas salvaguardas pueden ser técnicas, organizativas o de procedimiento, y su objetivo es reducir el riesgo de incidentes de seguridad y garantizar la continuidad del negocio.

Algunos ejemplos de salvaguardas en un SGSI basado en ISO/IEC 27001:2022 incluyen:



Controles técnicos: Implementación de firewalls, sistemas de detección y prevención de intrusiones, encriptación de datos, autenticación fuerte, actualizaciones regulares de software y parches de seguridad, copias de seguridad y recuperación de datos, entre otros.



Controles organizativos: Desarrollo de políticas de seguridad de la información, clasificación adecuada de la información, asignación de responsabilidades y roles claros, concienciación y formación en seguridad para empleados, gestión de accesos y permisos, evaluaciones periódicas de riesgos y auditorías de seguridad.



Controles de procedimiento: Establecimiento de procesos de gestión de incidentes de seguridad, revisiones regulares de configuración de sistemas, gestión de cambios controlados, procesos de gestión de proveedores y terceros, documentación de políticas y procedimientos de seguridad, entre otros.



Contratos o acuerdos con terceros: en algunas ocasiones la Organización transfiere algunos de los Riesgos asociados a sus activos, de tal manera que su riesgo queda mitigado o eliminado.

Gráfico 5: Identificación de Salvaguardas

4.1.4. Evaluación de Riesgo Inherente

El riesgo inherente, en el contexto de un Sistema de Gestión de Seguridad de la Información (SGSI), es el nivel de riesgo presente en un activo, sistema o

proceso específico antes de que se apliquen cualquier tipo de controles o salvaguardas para mitigarlo. Es, en esencia, el nivel "natural" de riesgo que se encuentra en un activo, sistema o proceso dada su naturaleza intrínseca y sin tener en cuenta cualquier medida de seguridad o control que se haya implementado.

En el proceso de gestión de riesgos, la evaluación de riesgo inherente es una parte esencial para determinar qué controles y medidas de seguridad deben implementarse para proteger los activos de información. Esta se evalúa considerando factores como la probabilidad de que una amenaza explote una vulnerabilidad y el impacto que esto podría tener sobre la organización.

La probabilidad, se evalúa en torno a la experiencia y conocimientos que se tenga del activo de información. Generalmente este criterio de probabilidad es cualitativo y, de acuerdo con la escala que se proponga puede transformarse en cuantitativo.

A continuación, proponemos la siguiente tabla de probabilidad de explotación de vulnerabilidades:

TABLA DE PROBABILIDAD			
NIVEL	DESCRIPTOR	DESCRIPCIÓN (FACTIBILIDAD)	FRECUENCIA
1	RARO	Puede que el riesgo no se haya presentado, o que ocurra solo en circunstancias excepcionales.	Nunca o no se ha presentado en los últimos 5 años
2	IMPROBABLE	El riesgo pudo ocurrir en algún momento, es poco común o frecuente	Al menos de 1 vez en los últimos 5 años.
3	POSIBLE	El riesgo puede ocurrir en algún momento.	Al menos de 1 vez en los últimos 2 años.
4	PROBABLE	El riesgo ocurrirá en la mayoría de las circunstancias.	Al menos de 1 vez en el último año.
5	CASI SEGURO	Se espera que el riesgo ocurra en la mayoría de las circunstancias.	Más de 1 vez al año.

Tabla 4: Tabla de Probabilidad

El impacto se medirá en relación con los criterios de Confidencialidad, Integridad y Disponibilidad, que el activo perdería si la amenaza llegase a materializarse. El promedio de estos valores se suele considerar como la probabilidad de materialización del Riesgo.

TABLA DE IMPACTO		
NIVEL	DESCRIPTOR	DESCRIPCIÓN
1	INSIGNIFICANTE	Si el hecho llegara a presentarse, tendría consecuencias o efectos MÍNIMOS sobre el proceso y/o la entidad.

2	MENOR	Si el hecho llegara a presentarse, tendría BAJAS consecuencias o efectos sobre el proceso y/o la entidad.
3	MODERADO	Si el hecho llegara a presentarse, tendría MEDIANAS consecuencias o efectos sobre el proceso y/o la entidad.
4	MAYOR	Si el hecho llegara a presentarse, tendría ALTAS consecuencias o efectos sobre el proceso y/o la entidad.
5	CATASTRÓFICO	Si el hecho llegara a presentarse, tendría DESASTROSAS consecuencias o efectos sobre el proceso y/o la entidad.

Tabla 5: Tabla de Impacto

Generalmente (aunque no siempre), se suele utilizar la fórmula **$R_i = P \times I$** , donde R_i es el Riesgo Inherente, P es la probabilidad de ocurrencia e I es el impacto causado por la ocurrencia del evento. La aplicación o no, de la fórmula mencionada, dependerá de la metodología de riesgos que haya adoptado la organización.

Ya con la ponderación del Riesgo, podremos asumir una Administración del Riesgo. Es decir, la organización deberá definir que estrategia de tratamiento de Riesgo asume para cada ponderación.

A continuación, se propone una tabla de Administración del Riesgo, que puede aplicarse a los Riesgos Inherentes y Residuales por igual.

ZONA DE RIESGO	ADMINISTRACIÓN DEL RIESGO	OPCIONES DE ADMINISTRACIÓN DEL RIESGO
BAJA	Se ACEPTAN las consecuencias o efectos de la materialización del riesgo; en este caso no es necesario tomar medidas para seguir disminuyendo la probabilidad e impacto del riesgo.	• Asumir el riesgo
MODERADA	Se toma medidas encaminadas a DISMINUIR tanto la PROBABILIDAD (medidas de prevención) , como el IMPACTO (medidas de protección) . La reducción del riesgo es probablemente el método más sencillo y económico para superar las debilidades antes de aplicar medidas más costosas y difíciles.	• Asumir el riesgo • Reducir el riesgo • Evitar el riesgo
ALTA	Se toma medidas encaminadas a PREVENIR que el riesgo se materialice, evitar la materialización del riesgo es la primera alternativa a considerar , y	• Reducir el riesgo • Evitar el riesgo

	esto se logra cuando al interior del proceso se generan CAMBIOS SUSTANCIALES, tales como: mejoramiento a raíz de ajustes drásticos, rediseños o eliminaciones realizados en procedimientos u otros controles establecidos.	• Compartir el riesgo • Transferir el riesgo
EXTREMA	Implica tomar medidas que REDUZCAN EL IMPACTO de la materialización del riesgo , a través del COMPARTIR O TRASPASO de las pérdidas potenciales a otras organizaciones o entidades, como en el caso de los contratos de seguros (Pólizas) u Outsourcing de servicios.	

Tabla 6: Administración del Riesgo

4.1.5. Identificación y Valoración de controles existentes

Los controles aplicados para cada Riesgo serán, cuando sea pertinente, los propuestos por la norma ISO/IEC 27002:2022, especificados en la declaración de aplicabilidad.

Para la valoración del Riesgo se tomarán en consideración los siguientes aspectos:

I. GRADO DE APLICACIÓN (A).

Define cómo es el nivel de aplicación de ese control. Para su valoración, podemos considerar aspectos como:

- Si existen herramientas informáticas o similares que permitan una gestión del control con independencia de personas.
- El control ha sido informado, es conocido por toda la organización o, como mínimo, por las personas y/o áreas afectadas por el mismo.
- El control es aceptado por el conjunto de la organización o por las personas y/o áreas sobre las que les es de aplicación. Es decir, que no existen eventos que puedan indicar que se ha dejado de aplicar por voluntad de personas.
- Si existen mecanismos de verificación del seguimiento del Control.

II. FRECUENCIA EN SU EJECUCIÓN Y SEGUIMIENTO (B).

Indica en qué grado están implementados la supervisión y el seguimiento del correspondiente control. Para poder valorar este factor se considera si:

- El control se realiza de forma sistemática y con la frecuencia necesaria para cumplir su objetivo.
- Se produce un seguimiento de su ejecución en los plazos establecidos sin necesidad de que sea requerido por la Alta Dirección.
- Se han establecido y definido los plazos de ejecución del control, su revisión y supervisión, realizándose de la forma preestablecida.
- Existen responsabilidades de sobre el seguimiento a su nivel de ejecución.

III. DETERMINACIÓN Y DEFINICIÓN DE RESPONSABLE/S (C).

Todos los controles deben estar reemplazado y tener al menos un responsable designado. Para poder dar respuesta a este control se considera si:

- Existen responsables predefinidos de la correcta ejecución del control.
- Existe una supervisión constante de los responsables de la ejecución del control.
- Entre las responsabilidades de los puestos existentes se encuentra la correcta supervisión del mencionado control.
- Existen sistema de medición del desempeño que tienen en cuenta la correcta ejecución de los controles a sus responsables.

IV. CARÁCTER PREVENTIVO (D).

Para aportar efectividad al sistema de gestión, se espera que los controles puedan ser preventivos. Para poder dar respuesta a este control, se considera si:

- El control permite actuar de forma que restrinja la comisión de la actividad que puede generar el riesgo.
- El control facilita o dispone de la existencia de mecanismos de información e identificación de una amenaza con tiempo suficiente para articular una reacción frente a la misma.
- Las personas responsables del control disponen de los recursos, medios y autoridad suficientes para abortar un peligro de amenaza.

- Existen protocolos establecidos en la organización para proceder ante un riesgo advertido por el control.

V. GRADO DE DOCUMENTACIÓN O EVIDENCIA (E).

Todo el sistema de gestión debe estar documentado y generar evidencias repetibles. Para poder dar respuesta a este control, se considera si:

- Existen documentos o registros que puedan acreditar el cumplimiento del control.
- Los registros o documentos acreditativos del cumplimiento del control se custodian de una forma eficiente que garantice que no se pueda extraviar, destruir, etc.
- Los documentos que evidencian el cumplimiento acreditan de forma verificable que el control se ha ejecutado cuando se ha establecido.
- Existen responsabilidades definidas en materia de supervisión o seguimiento a la recopilación de evidencias.

La calificación de cada control puede ser cualitativos o cuantitativos y, su valor final, debe afectar a la calificación del Riesgo Inherente antes evaluado.

4.1.6. Evaluación de la Efectividad de los Controles

El valor de efectividad del control o grupo de controles debe calcularse con los valores cuantitativos otorgados a cada control. El método de cálculo mas aceptado es el PROMEDIO; sin embargo, este cálculo dependerá de la metodología que haya adoptado la organización para en análisis y gestión de riesgos.

4.1.7. Evaluación y calificación del Riesgo Residual

El riesgo residual, según la norma ISO/IEC 27001:2022, se refiere al nivel de riesgo que queda después de que se han implementado los controles de seguridad.

Generalmente, aunque no siempre, se suele utilizar la fórmula **$R_r = R_i * C$** , donde R_r es el Riesgo Residual, R_i es el Riesgo Inherente y C es el cálculo de la efectividad de los controles aplicados. De igual manera este cálculo

dependerá de la metodología que haya adoptado la organización para en análisis y gestión de riesgos.

Para la calificación del riesgo residual, se puede proceder de la misma manera que para los riesgos inherentes.

4.2. Criterio de aceptación de Riesgos

Este criterio define el “apetito del Riesgo” que la organización decide aceptar o, en otras palabras: hasta que umbral de Riesgo, la organización “acepta el riesgo^[9]”.

La norma ISO/IEC 27001:2022 no prescribe un criterio específico de aceptación de riesgos, ya que esto depende de la individualidad de la organización y su apetito o tolerancia al riesgo. Sin embargo, la norma ISO/IEC 27005:2022 proporciona una estructura y directrices para establecer y aplicar un proceso formal de gestión de riesgos, lo cual incluye la definición de criterios de aceptación de riesgos.

Los criterios de aceptación de riesgos son los niveles de riesgo que una organización está dispuesta a aceptar. Estos criterios son fundamentales para determinar qué riesgos necesitan ser tratados y qué métodos de tratamiento de riesgos son apropiados.

Un criterio de aceptación de riesgos puede ser cualitativo o cuantitativo:

- **Criterio cualitativo:** Puede implicar la clasificación de los riesgos en categorías como "bajo", "medio" y "alto". Por ejemplo, una organización puede estar dispuesta a aceptar riesgos clasificados como "bajos", pero puede requerir que se tomen medidas para mitigar cualquier riesgo clasificado como "medio" o "alto".
- **Criterio cuantitativo:** Puede implicar el uso de un umbral numérico. Por ejemplo, si una organización utiliza una escala numérica para calificar el riesgo, puede establecer que está dispuesta a aceptar cualquier riesgo con una calificación inferior a 4 en una escala de 1 a 10.

Es importante tener en cuenta que la aceptación de riesgos no significa que los riesgos sean ignorados. Aun cuando un riesgo se acepta, debe ser monitoreado y revisado periódicamente para asegurar que sigue siendo aceptable y no ha aumentado a un nivel que ahora requeriría tratamiento.

4.3. Declaración de aplicabilidad

La Declaración de Aplicabilidad (SoA^[10], por sus siglas en inglés) es un documento clave en el proceso de implementación de un SGSI y la norma ISO/IEC 27001:2022. La SoA describe los controles seleccionados para tratar los riesgos identificados, junto con una justificación para su selección y un plan de implementación. La SoA debe ser revisada y actualizada periódicamente para asegurar que los controles sigan siendo relevantes y eficaces en el tratamiento de los riesgos.

Esta declaración de aplicabilidad guarda relación directa a los riesgos detectados y valorados y el alcance definido para el SGSI.

Adicionalmente se debe indicar que, el SoA basa su contenido en la norma ISO/IEC 27002:2022, que se abordará en el siguiente capítulo.

5. Temas de seguridad de la información según ISO/IEC 27002:2022

La nueva norma ISO/IEC 27002:2022, presenta controles con un enfoque principalmente preventivo / detectivo (93 controles).

TEMAS ISO/IEC 27001:2022		CONTROLES
A.5	Organización	37
A.6	Personas	8
A.7	Seguridad Física	14
A.8	Personas	34
TOTAL CONTROLES		93

Tabla 7: Temas ISO/IEC 27002:2022

Tal como se vio en la Tabla 1, la cantidad de controles o de temas propuestos por la norma ISO/IEC 27002:2022, se “redujo” de 114 a 93 desde la versión 2017 a la versión 2022. No es así. Los anteriores 114 Controles se mantienen “fusionados o reorganizados” y, en adición, se proponen 11 nuevos Controles (estos si, totalmente nuevos). Por lo que, al momento de implementar la norma, algunas definiciones parten de la versión 2017.

Ahora bien, los Temas que presenta la norma ISO/IEC 27002:2022, son más concisos y enfocados en aspectos intrínsecos de la Seguridad de la Información; dando más peso a los controles Organizacionales y del Talento Humano (45 controles).

Otro de los aspectos, con respecto a la versión anterior, es que, anteriormente, no se definía que tipo de control es el que se proponía (Preventivo, Detectivo o Correctivo) y a que característica de la Seguridad de la Información afecta (Confidencialidad, Integridad o Disponibilidad). Estos aspectos han sido cubiertos por la nueva versión y, adicionalmente incluyen conceptos altamente reconocidos de ciberseguridad del **framework NIST** como son: Identificar, Detectar, Proteger, Recuperar y Responder. Toma en consideración las Capacidades Operacionales de la Organización, es decir, la capacidad que tiene la Organización para el uso del Control en determinado aspecto Organizativo. Así como también hace especial énfasis en el análisis de Riesgos de Seguridad de la Información, enfocado principalmente en los Dominios de Seguridad (Gobernanza, Resiliencia, Defensa y Protección)

De tal modo que un control podría mapearse como sigue:

Tema	Tecnología			
Control	A.8.3 Restricción de acceso a la información			
Tipo de Control	Propiedades de SI	Concepto de ciberseguridad	Capacidades operacionales	Dominios de seguridad
Preventivo	Confidencialidad Integridad Disponibilidad	Proteger	Gestión de identidad y acceso	Protección
Definición del control			Propósito del Control	
El acceso a la información y otros activos asociados debe estar restringido de acuerdo con la política específica del tema establecida sobre control de acceso.			Controlar el acceso a la información de la organización. Aplicación de la política de control de acceso.	

Tabla 8: Mapa de Control ISO/IEC 27002:2022

Adicionalmente, los 11 nuevos controles, están enfocados principalmente en la Ciberseguridad y la Resiliencia Organizacional. Aquí se tocan temas como por ejemplo la Seguridad de la Información en el uso de servicios de Nube (esto a propósito de la masificación del uso de nubes como Azure, AWS, Google, etc. o de nubes privadas dentro de la infraestructura tecnológica de la Organización) o incluso el Monitoreo de la Seguridad Física que debe existir en cada Organización.

El desglose de la norma ISO/IEC 27002:2022 se encuentra en el **ANEXO B**, del presente libro.

6. Monitoreo, medición, análisis y evaluación

6.1. Monitoreo y medición de la efectividad de los controles

Para garantizar la eficacia de los controles de seguridad de la información, es fundamental realizar un monitoreo y medición continuos. Esto es esencial para garantizar que los controles están funcionando como se espera y para identificar cualquier área de mejora.

Este es un proceso continuo que incluye la identificación de las métricas que serán utilizadas para medir la efectividad de los controles, la recopilación y análisis de los datos correspondientes, y la utilización de esta información para tomar decisiones informadas y mejorar el SGSI.

- **Identificación de métricas:** Las métricas deben ser seleccionadas cuidadosamente para reflejar la efectividad de los controles implementados. Las métricas pueden ser cuantitativas o cualitativas y deben ser relevantes para los objetivos de seguridad de la información de la organización.
- **Recopilación de datos:** Los datos relacionados con las métricas identificadas deben ser recopilados de manera sistemática y regular. Esta recopilación puede implicar la revisión de los registros de

seguridad, la realización de auditorías o el seguimiento de otros indicadores relevantes.

- **Análisis de los datos:** Los datos recogidos deben ser analizados para evaluar la efectividad de los controles. Esto puede implicar el uso de técnicas estadísticas, la comparación con los umbrales o criterios establecidos, o la revisión de las tendencias a lo largo del tiempo.
- **Toma de decisiones y mejora:** Los resultados del análisis de los datos deben ser utilizados para tomar decisiones sobre la mejora del SGSI. Esto puede implicar la modificación de los controles existentes, la implementación de nuevos controles, o la revisión de los objetivos de seguridad de la información.
- **Comunicación de los resultados:** Los resultados del monitoreo y la medición deben ser comunicados a las partes interesadas relevantes, incluyendo la alta dirección y los empleados. Esto puede ayudar a crear una mayor conciencia sobre la seguridad de la información y a fomentar una cultura de seguridad en la organización.

Es importante recordar, que este es un proceso continuo y, que el SGSI debe ser revisado y mejorado de forma regular para garantizar su efectividad en un entorno que está en constante cambio.

6.2. Auditorías internas y externas

Las auditorías internas y externas son una parte esencial de la gestión de la seguridad de la información. Estas son evaluaciones sistemáticas e independientes de los controles, procesos y políticas de una organización en relación con la norma ISO/IEC 27001:2022 y otros requisitos aplicables.

Generalmente, se denomina Auditoría de Segunda Parte a las Auditorías Internas y, Auditorías de Tercera Parte a las Auditorías de Certificación o Seguimiento.

Auditorías Internas

La principal ventaja de realizar auditorías internas, es que permiten realizar un seguimiento constante de los procesos y controles de seguridad aplicados. Las auditorías internas, pueden ser realizadas por personal de la organización o consultores contratados. Su objetivo es identificar áreas de mejora, fallos en los sistemas y procesos, y desviaciones de las políticas establecidas.

Las auditorías internas, proporcionan la capacidad de probar y validar los controles de seguridad antes de una auditoría externa. De este modo, se reducen los riesgos de encontrar no conformidades durante una auditoría externa.

Auditorías Externas

Las auditorías externas, por otro lado, son realizadas por organismos de certificación acreditados. El objetivo de estas Auditorías es la validación independiente de que el sistema de gestión cumple con lo requerido por la norma ISO/IEC 27001.

Las auditorías externas son una necesidad, si se busca obtener la certificación ISO/IEC 27001.

6.3. Evaluación y revisión de riesgos

La evaluación y revisión periódica de los riesgos de seguridad de la información es esencial para mantener un SGSI efectivo y adaptarse a los cambios en el entorno de amenazas y las necesidades de la organización.

Las amenazas cambian con el tiempo, lo mismo las vulnerabilidades. Por lo tanto, es necesario evaluar y revisar continuamente la matriz de riesgos del SGSI. Esta debe revisarse cuando: exista un cambio importante en el contexto de la organización, se actualice la lista de activos de información, haya pasado al menos 6 meses desde la última revisión o cuando la organización estime pertinente.

6.4. Mejora continua

La mejora continua es un principio fundamental de la gestión de la seguridad de la información y un componente clave del ciclo de vida del SGSI.

Se espera que el SGSI sea siempre relevante, efectivo y alineado a los objetivos de la organización; por lo que el monitoreo, medición y evaluación de riesgos, derivan en acciones que la organización toma para mejorar sus procesos y sistemas de manera continua, apoyado, por supuesto, en el SGSI.

Hay que recordar que la mejora continua es un proceso cíclico. Después de la revisión del SGSI, se debe volver a las actividades de monitoreo, medición y evaluación, y el ciclo continúa. De esta manera, tu SGSI siempre se está adaptando y mejorando, asegurando que proporciona el mejor nivel posible de protección para los activos de información de la organización.

7. Mantenimiento y mejora continua del SGSI

7.1. Revisión y actualización de la política de seguridad de la información

Las políticas de seguridad de la información deben ser revisadas y actualizadas regularmente para asegurar que sigan siendo relevantes y efectivas.

La política de seguridad de la información debe ser revisada y actualizada cuando: exista un cambio importante en el contexto de la organización, haya pasado al menos 1 año desde la última revisión o cuando la organización estime pertinente.

Hay que tener presente las recomendaciones que da la norma para una correcta redacción de la política de seguridad de la información, abordado ya en capítulos anteriores.

7.2. Revisión y ajuste de los controles de seguridad

Los controles de seguridad de la información deben ser revisados y ajustados según sea necesario para abordar los cambios en el entorno de amenazas, las necesidades de la organización y los resultados de las evaluaciones de riesgos y auditorías.

Los controles de seguridad deben ser revisados y ajustados cuando: exista un cambio importante en el contexto de la organización, exista cambios o inclusiones en los activos de información, haya pasado al menos 1 año^[11] desde la última revisión o cuando la organización estime pertinente.

7.3. Capacitación y concientización en seguridad de la información

La capacitación y concientización en seguridad de la información son fundamentales para garantizar que los empleados y otras partes interesadas comprendan sus responsabilidades y sigan las políticas y procedimientos de seguridad establecidos.

Para capacitar y concientizar en seguridad de la información, se sugiere seguir el siguiente proceso:

- **Definición de objetivos.** – La capacitación y concientización debe tener objetivos claros y medibles. Además, estos deben estar alineados a los objetivos de la seguridad de la información que se plantearon en la política del SGSI.
- **Diseño del Programa de Capacitación y Concientización.** – Se debe revisar la matriz de riesgos e identificar los puntos de mejora que hacen falta cubrir. Estos pueden ser o no temas técnicos, como, por ejemplo: el manejo de activos, el etiquetado de la información, los procesos de seguridad de la información de un área en particular, etc.
- **Implementación de Programas de Capacitación y Concientización.** – Esto podría realizarse a través de una combinación de capacitaciones presenciales, línea, folletos, etc [\[12\]](#).
- **Monitoreo y Revisión.** – Es crucial evaluar la eficacia de los programas de capacitación y concientización. Esto podría hacerse a través de pruebas y evaluaciones, así como también a través de la recopilación de comentarios de los participantes. Los resultados de estas evaluaciones deben utilizarse para mejorar los programas de capacitación.
- **Registro de la Capacitación.** – Para cumplir con la norma ISO/IEC 27001, se debe mantener un registro de todas las capacitaciones realizadas, incluyendo la cantidad de participantes, el contenido de la capacitación, la fecha y el lugar de la capacitación, y los resultados de las pruebas o evaluaciones realizadas.

7.4. Evaluación del desempeño del SGSI

La evaluación del desempeño del SGSI implica medir la efectividad del sistema en la protección de la información y la reducción de riesgos, y en cumplir con los objetivos y metas establecidos.

La evaluación del desempeño es una parte esencial del ciclo de mejora continua del SGSI, y ayuda a la organización a determinar si se están cumpliendo los objetivos de seguridad de la información, o si existe alguna desviación; esta se realiza utilizando una variedad de métodos, entre las que anotamos:

- **Auditoría Interna:** La norma ISO/IEC 27001:2022 requiere que se realicen auditorías internas regulares del SGSI para verificar que se están siguiendo los procedimientos y políticas implementados. La finalidad de una auditoría interna es verificar que el SGSI cumple con los requisitos de esta norma internacional.
- **Revisión por la Dirección:** La alta dirección debe revisar el SGSI a intervalos planificados para asegurarse de su continua idoneidad, adecuación y efectividad. La revisión por la dirección puede incluir la consideración de resultados de auditorías, comentarios de partes interesadas, estado de las acciones correctivas, y cambios que pueden afectar al SGSI.
- **Medición y Análisis:** La norma ISO/IEC 27001 requiere que la organización determine y aplique métodos para medir, monitorear, analizar y evaluar el SGSI. Esto puede implicar la identificación y seguimiento de métricas de desempeño de seguridad de la información, como el número de incidentes de seguridad, la frecuencia de las pruebas de sistemas y aplicaciones, y el tiempo de respuesta a los incidentes de seguridad.
- **Evaluación de la Eficacia de los Controles:** Como parte del análisis de riesgos del SGSI, la organización debe evaluar regularmente la eficacia de los controles de seguridad de la información implementados. Esto puede implicar pruebas de penetración, revisiones de configuración, y evaluaciones de cumplimiento de las políticas y procedimientos de seguridad.
- **Tratamiento de No Conformidades y Acciones Correctivas:** Cuando se identifica una NO conformidad con los requisitos del SGSI, la organización debe tomar acciones para corregirla y prevenir su recurrencia. Las no conformidades y las acciones correctivas tomadas deben ser documentadas y revisadas para evaluar su eficacia.

El proceso de evaluación del desempeño del SGSI debe estar documentado y ser regular, sistemático y objetivo. Esto proporciona evidencia de que el SGSI es eficaz y está cumpliendo con los requisitos de la norma ISO/IEC 27001.

8. Preparación y obtención de la certificación ISO/IEC 27001

8.1. Entendiendo los requisitos de la certificación ISO/IEC 27001

La certificación ISO/IEC 27001 es un reconocimiento internacional de que una organización ha implementado y mantiene un SGSI eficaz y conforme a las mejores prácticas de seguridad de la información. Los requisitos que se especifican en esta norma incluyen:

- **Contexto de la organización (4.1):** Es imprescindible que, al inicio de la implementación de esta norma, se considere seriamente el conocimiento del Contexto de la Organización. Comprender la organización y su contexto, las necesidades y expectativas de las partes interesadas, el alcance del SGSI y el sistema de gestión de seguridad de la información.

- Contexto Interno y Externo

El contexto interno y externo, con el que lidia la organización es un aspecto fundamental que influye directamente en su capacidad para lograr sus objetivos estratégicos y operativos, incluyendo aquellos relacionados con la gestión de riesgos, el cumplimiento de normativas y el desempeño general. Entender y gestionar este contexto es clave para el éxito de la implementación y mantención del SGSI. En este punto se pueden utilizar varias herramientas de análisis como la Matriz FODA, Análisis PESTEL, Cadena de valor de PORTER, etc.

- Modelo de Negocio

Conocer el modelo de negocio es fundamental en una implementación de SGSI. Muchos consultores, desestiman este conocimiento dado que implica entrar al detalle de las entradas, procesos y salidas de los productos o servicios que la organización oferta. Sin embargo, el conocer el modelo de negocio, habilita al implementador a sugerir el mejor alcance de implementación, ya sea este por procesos de negocio, áreas organizativas o sistemas particulares. Para esto, el implementador puede solicitar el modelo de negocio o, en su defecto, apoyar a la

organización a la graficar el suyo propio; para eso puede ayudarse del Lienzo de Modelo de Negocio CANVAS (Business Model Canvas).

- Marco Legal

Hay que recordar que la norma ISO/IEC 27001:2022 es una norma internacional; por lo tanto, es ajena a cualquier regulación nacional en donde se implemente. En muchos países, se ha extendido la necesidad de protección de datos personales (por ejemplo), y cuentan con regulaciones y particularidades independientes. Por lo que resulta importante que el implementador conozca las regulaciones del país, que hacen referencia a buenas prácticas de seguridad y privacidad de la información.

- Partes interesadas

Las partes interesadas, son todas las personas naturales, entidades de control, clientes, proveedores y terceros, que se benefician con la existencia de la organización. Entre las partes interesadas podrían estar: empleados, contratistas, proveedores, accionistas, entes gubernamentales, etc. Esta norma internacional, solicita que se realice un relevamiento de las partes interesadas, cuales son sus necesidades y sus expectativas en referencia a la seguridad de la información y a la organización en general.

- Definición del Alcance del SGSI

Lo ideal siempre será la implementación de esta norma internacional en toda la organización; sin embargo, esto dependerá del tamaño y complejidad de esta. Esto, sin considerar el esfuerzo económico y organizacional que esto implica. Por lo que, el implementador, al conocer el contexto organizacional, el modelo de negocio y las partes interesadas, puede, sin lugar a duda, definir un alcance de implementación realista y que cumpla con las expectativas y necesidades de la organización.

- **Liderazgo:** La alta dirección debe demostrar liderazgo y compromiso con el SGSI. Este liderazgo se verá reflejado en el establecimiento de una política de seguridad de la información, la asignación de roles y responsabilidades para la seguridad de la información y la revisión y monitoreo continuo del sistema.

- Política de Seguridad de la Información debe ser acorde a la realidad organizacional y reflejar el compromiso de la alta dirección con la aplicación de esta norma internacional. [\[13\]](#)
- La alta dirección (o quien haga sus veces), deberá designar a una persona o equipo la responsabilidad de implementar y mantener un SGSI. Lo ideal es que esta persona o equipo cuente con la suficiente independencia dentro la organización y tenga el respaldo visible de la alta dirección en sus decisiones.
- **Planificación:** La organización debe planificar acciones para gestionar y abordar los riesgos de seguridad de la información, así como las estrategias para alcanzar los objetivos de seguridad de la información y la gestión del cambio organizacional y sus efectos en el SGSI.
 - La gestión del riesgo para un SGSI, se debe a una metodología que la organización puede escoger o elaborar [\[14\]](#).
 - Cabe indicar que, tanto los planes de gestión de riesgos como los objetivos de seguridad de la información, deben ser medibles, considerando que estos indicadores deben ser SMART.
- **Apoyo:** La organización debe proporcionar recursos para el SGSI, asegurar que las personas son conscientes de sus responsabilidades de seguridad de la información, gestionar el conocimiento competente, comunicar acerca del SGSI y controlar la información documentada.
 - La organización, debe considerar que, para que una implementación de SGSI sea exitosa, debe proporcionar recursos humanos [\[15\]](#) y económicos.
 - La alta dirección debe saber, además, que el éxito o fracaso en la implementación o mantención del SGSI, es tarea de toda la organización. Se ha visto en muchos escenarios que la falta de cultura organizacional o la resistencia al cambio son factores decisivos al momento de marcar el éxito o el fracaso de esta implementación.
- **Operación:** La organización debe planificar, implementar y controlar los procesos, evaluar los riesgos de seguridad de la información y

planificar cómo tratarlos, y gestionar cambios^[16].

- **Evaluación del rendimiento:** La organización debe monitorear, medir, analizar y evaluar el estado de la seguridad de la información, llevar a cabo auditorías internas del SGSI y revisar el SGSI a intervalos planificados.
 - La calidad y cantidad de indicadores de gestión son claves para la revisión del desempeño del SGSI.
 - Los indicadores deben reflejar en primera instancia los objetivos de seguridad de la información que la organización se ha planteado, luego los riesgos mas relevantes que se han identificado, por último, los riesgos operativos que pueden afectar la seguridad de la información.
 - De igual manera, los indicadores deben tener responsables, métodos de evaluación y tiempos regulares de medición.
- **Mejora:** La mejor manera de conocer la efectividad del SGSI es realizando Auditorías. Una Auditoría Interna o de Certificación reflejará no conformidades y desviaciones del sistema.
 - Estas actividades deben derivar en la toma de acciones correctivas, que mejoraren continuamente la adecuación y efectividad del SGSI.
 - La Auditoría Interna es un requisito indispensable para cualquier organización que desea certificarse en esta norma internacional.
 - Adicionalmente, es importante que se realice una planificación y ejecución de Auditorías de segunda y tercera partes de manera programada, ya sea esta sobre todo el sistema de gestión, o sobre parte de ella.
 - Hay que considerar que para obtener la certificación ISO/IEC 27001:2022, la organización debe someterse a una auditoría por parte de un organismo de certificación acreditado que evaluará la conformidad de la organización con los requisitos de la norma.

Además de estos requisitos generales, la norma ISO/IEC 27001:2022 incluye una serie de controles de seguridad de la información en su Anexo A y que

son los que se incluyen en la norma ISO/IEC 27002:2022 que las organizaciones pueden implementar dependiendo de sus necesidades específicas. Esto incluye controles en áreas como la seguridad física, la gestión de activos, el acceso a la información, la gestión de incidentes de seguridad de la información, la continuidad del negocio, el cumplimiento, etc.

8.2. Selección de un organismo de certificación

La elección de un organismo de certificación adecuado es un paso crucial en el proceso de certificación ISO/IEC 27001:2022. En Ecuador y en América Latina, existen varios organismos de certificación que se encargan de evaluar la conformidad de los sistemas de gestión, de acuerdo con estándares nacionales e internacionales. Algunos de los más reconocidos se anotan:

- Instituto Ecuatoriano de Normalización (INEN): Este organismo se encarga de la normalización en Ecuador y tiene como misión proteger la salud y seguridad de los consumidores, así como facilitar el comercio a través de normas técnicas.
- Bureau Veritas del Ecuador: Es parte de una red internacional de servicios de ensayo, inspección y certificación.
- SGS del Ecuador: También parte de una red internacional ofrece servicios de certificación en áreas como calidad, medio ambiente, seguridad y salud ocupacional, y responsabilidad social.
- Instituto Colombiano de Normas Técnicas y Certificación (ICONTEC): Es el organismo de certificación y normalización más importante de Colombia. Realiza certificaciones para varios sectores.
- BSI Group (British Standards Institution): BSI tiene operaciones en varias partes del mundo, incluyendo América Latina.

Es importante notar que muchos de estos organismos son miembros de la International Organization for Standardization (ISO), lo que significa que siguen los estándares internacionales en sus procesos de certificación.

8.3. Preparación para la auditoría de certificación

La preparación para la auditoría de certificación ISO/IEC 27001:2022 implica asegurar que la organización cumple con todos los requisitos de la norma y

está lista para demostrar la efectividad de su SGSI ante un organismo de certificación.

La preparación para una auditoría de certificación puede ser un proceso riguroso que requiere una planificación cuidadosa y una ejecución efectiva. Aquí hay algunos pasos clave que pueden ayudar a preparar a la organización para una auditoría de certificación:

- **Revisión del sistema actual:** Se deberá analizar los procesos y políticas actuales en relación con los estándares de certificación. Esto te permitirá identificar las brechas y áreas de mejora.
- **Implementar cambios:** Una vez identificadas las brechas, se necesitará trabajar para llenarlas. Esto puede incluir la implementación de nuevos procesos, políticas, procedimientos y/o tecnologías.
- **Capacitación del personal:** Todos los empleados deben estar al tanto de los estándares de certificación, especialmente aquellos que son relevantes para sus funciones laborales específicas. La capacitación debe ser continua para garantizar que todos los miembros de la organización comprendan y cumplan los estándares.
- **Realizar auditorías internas:** Antes de la auditoría oficial, se recomienda realizar una auditoría interna. Esto puede ayudarte a encontrar y corregir cualquier problema antes de la auditoría de certificación.
- **Recopilar evidencia:** En una auditoría de certificación la organización tendrá que demostrar cumplimiento, y eso generalmente significa proporcionar documentación. Esto puede incluir políticas escritas, registros de capacitación, resultados de pruebas, etc.
- **Preparar a los empleados para la auditoría:** La organización debe asegurarse de que sus empleados sepan qué esperar durante la auditoría. Deben estar preparados para responder a preguntas sobre sus roles y responsabilidades, así como los procesos y políticas que utilizan en su trabajo.
- **Cooperar con los auditores:** Durante los procesos de auditoría, el personal debe ser lo más cooperativo posible con los auditores.
- **Seguimiento:** Una vez que se complete la auditoría, es probable que recibas un informe con hallazgos y recomendaciones. Tendrás que

abordar estos problemas y hacer los cambios necesarios.

Se debe recordar que el objetivo de la auditoría de certificación no es solo obtener la certificación, sino también mejorar los procesos y la calidad en la organización. Por tanto, se debe tratar este proceso como una oportunidad para aprender y crecer.

8.4. Mantenimiento y renovación de la certificación ISO/IEC 27001

Una vez obtenida la certificación ISO/IEC 27001:2022, es fundamental mantener y mejorar continuamente el SGSI para asegurar que siga siendo efectivo y conforme a la norma.

Es usual que el ente certificador, realice Auditorías de Seguimiento de manera anual, por lo que la preparación de la organización para este evento debe ser continuo. No hay que olvidar que uno de los requisitos principales para la realización de estas Auditorías, es la realización previa de Auditorías Internas que, dependiendo del tamaño de la empresa y el sector, pueden ser semestrales.

9. Casos de éxito y de fracaso

9.1. Análisis de casos de éxito

A continuación, se presenta un caso de estudio de la implementación exitosa de la norma ISO/IEC 27001 en América Latina.

Empresa: Telefónica Movistar Ecuador

Antecedentes:

Telefónica Movistar Ecuador es una de las principales empresas de telecomunicaciones del país. La compañía se dio cuenta de la importancia de la seguridad de la información y decidió que quería certificarse en la norma ISO/IEC 27001 para garantizar que estaba utilizando las mejores prácticas posibles.

Implementación:

Telefónica Movistar decidió contratar a un equipo de consultores para que los ayudaran con el proceso de certificación. Los consultores comenzaron realizando una evaluación de los procesos existentes y la seguridad de la

información en la empresa. Luego, se identificaron las brechas y se implementaron medidas para corregirlas.

Se creó un comité de seguridad de la información, que incluía a representantes de todas las áreas de la empresa. Este comité fue responsable de implementar y supervisar las políticas de seguridad de la información.

Telefónica Movistar también llevó a cabo una serie de capacitaciones para todos sus empleados, enseñándoles la importancia de la seguridad de la información y cómo podrían contribuir a ella.

Resultado:

Después de un proceso de aproximadamente un año, Telefónica Movistar Ecuador logró obtener la certificación ISO/IEC 27001. La compañía fue reconocida por su Compromiso con la seguridad de la información y su esfuerzo por seguir las mejores prácticas internacionales.

Impacto:

Obtener la certificación ISO/IEC 27001 no solo proporcionó a Telefónica Movistar Ecuador un sello de aprobación internacional para su seguridad de la información, sino que también mejoró su imagen ante los clientes, los cuales se sintieron más seguros al utilizar los servicios de la compañía. Además, la implementación de las políticas de seguridad de la información ayudó a prevenir incidentes de seguridad, lo que a su vez evitó el costo y la interrupción asociados con estos eventos.

Este caso muestra que, aunque la implementación de la norma ISO/IEC 27001 puede requerir un esfuerzo considerable, los beneficios potenciales, tanto en términos de seguridad de la información como en la percepción del cliente, pueden ser significativos.

9.2. Estudio de casos de fracaso

Es muy complicado que existan empresas que compartan sus experiencias de fracaso en cualquier sentido y, mas aun en una implementación de esta envergadura. Por lo que mencionaremos los puntos que determinan el fracaso de un proyecto de implementación:

- **Falta de Compromiso de la alta dirección:** Uno de los principales problemas es la falta de Compromiso y participación activa de la alta dirección. Es indispensable que se destinen recursos económicos, de tiempo y de liderazgo para la eficaz implementación del SGSI.

- **Incomprensión de los requisitos:** La norma ISO/IEC 27001 es bastante compleja y requiere un entendimiento profundo de sus requisitos. Si el equipo implementador no tiene suficiente capacitación ni experiencia en el manejo de esta norma, llevará a interpretaciones incorrectas y a no cumplir con todos los requisitos necesarios.
- **Cultura organizacional:** La implementación de un SGSI, cambia la Cultura Organizacional. Si esta falla en implementarse por cualquier motivo, el proyecto estará destinado al fracaso. Los empleados deben entender la importancia de la seguridad de la información y la necesidad de seguir nuevos procedimientos y políticas que mejoran la SI dentro de la organización.
- **Falta de un enfoque sistemático:** El orden y sistematización, pueden ser cruciales a la hora de llevar con éxito esta implementación. El liderazgo de la Alta Dirección, los controles del Anexo A, la metodología de Riesgos, etc. deben ser abordados en orden y con una sistematización precisa, de manera que toda la empresa sepa los cambios y mejoras que se están aplicando. Por ejemplo: es muy complicado analizar los Riesgos de la SI, sin una metodología establecida y aprobada por la organización. Además, los resultados no serán repetibles ni correctamente evidenciados.

10. Recursos para la implementación de la norma ISO/IEC 27001:2022

10.1. Plantillas y documentos de referencia

Para facilitar la implementación de la norma ISO/IEC 27001:2022, a continuación, se listan una serie de plantillas y documentos de referencia que les ayudarán a desarrollar políticas de seguridad de la información, procedimientos, planes de gestión de riesgos y otros documentos esenciales para un SGSI eficaz y conforme a la norma. Estos estarán desarrollados en su totalidad en el siguiente capítulo, Anexos, del presente libro:

- a) Política de seguridad de la información: Un documento formal en el que la dirección se compromete a implementar la seguridad de la información.
*Revisar el **ANEXO A** del presente libro.*

- b) Declaración de aplicabilidad (SoA): Un documento que lista todos los controles del Anexo A de ISO/IEC 27001, y declara cuáles son aplicables y cuáles no, y por qué. *Revisar el **ANEXO B** del presente libro.*
- c) Análisis/Valoración de riesgos: Un proceso formal para identificar, valorar y tratar los riesgos de seguridad de la información. *Revisar el **ANEXO C** del presente libro.*
- d) Plan de tratamiento de riesgos: Un plan que detalla cómo la organización planea tratar los riesgos identificados durante la valoración de riesgos. *Revisar el **ANEXO D** del presente libro.*
- e) Objetivos de seguridad de la información: Los objetivos específicos que la organización ha establecido para mejorar la seguridad de la información. *Revisar el **ANEXO E** del presente libro.*
- f) Política de control de acceso: Un documento que establece cómo se otorgan y se revocan los derechos de acceso a los sistemas de información. *Revisar el **ANEXO F** del presente libro.*
- g) Política de clasificación de la información: Un documento que establece cómo se clasifica, etiqueta y maneja la información. *Revisar el **ANEXO G** del presente libro.*
- h) Plan de respuesta a incidentes: Un plan que detalla cómo la organización responderá a los incidentes de seguridad de la información. *Revisar el **ANEXO H** del presente libro.*
- i) Revisión por la dirección: Registros que demuestran que la organización está revisando y mejorando activamente su SGSI. *Revisar el **ANEXO I** del presente libro.*

10.2. Software y herramientas de gestión de riesgos

A continuación, se muestra un listado de algunas herramientas y software de gestión de riesgos disponibles en el mercado:

- SAP Risk Management: Proporciona un enfoque integrado para la gestión de riesgos empresariales y permite identificar, evaluar y mitigar riesgos en toda la organización.
- IBM OpenPages: Ofrece una plataforma de gestión de riesgos y cumplimiento que ayuda a las organizaciones a identificar y mitigar riesgos, así como a cumplir con regulaciones y estándares.

- RSA Archer: Permite gestionar riesgos de manera integral, incluyendo la identificación, evaluación y mitigación de riesgos operativos, de cumplimiento y de seguridad.
- MetricStream: Proporciona una plataforma de gestión de riesgos y cumplimiento que ayuda a las organizaciones a identificar, evaluar y gestionar riesgos en toda la empresa.
- Riskconnect: Ofrece una solución de gestión de riesgos integrada que abarca desde la identificación y evaluación de riesgos hasta la implementación de planes de mitigación.
- LogicManager: Proporciona una plataforma de gestión de riesgos que ayuda a las organizaciones a identificar, evaluar y mitigar riesgos en diferentes áreas, como riesgos operativos, de cumplimiento y de seguridad.
- MEGA International: Ofrece una solución de gestión de riesgos empresariales que permite identificar y evaluar riesgos, así como desarrollar estrategias de mitigación.
- Resolver: Proporciona una plataforma de gestión de riesgos integrada que incluye funcionalidades de identificación de riesgos, evaluación, análisis de brechas y seguimiento de planes de acción.
- Galvanize HighBond: Ofrece una solución de gestión de riesgos y cumplimiento que abarca diferentes áreas, como riesgos financieros, operativos y de TI.
- Protecht: Proporciona una plataforma de gestión de riesgos y cumplimiento que ayuda a las organizaciones a identificar, evaluar y mitigar riesgos en tiempo real.

Sin embargo, cada una de las herramientas, utiliza su propia metodología de análisis y evaluación de riesgos y, como se anotó anteriormente, cada organización es libre de ocupar la metodología que mas se ajuste a sus necesidades. Incluso, en este mismo libro, se detalla una metodología eficaz para la necesitarás solo una hoja de cálculo.

10.3. Fuentes de información y actualización sobre seguridad de la información

Para mantenerse actualizados en el campo de la seguridad de la información y la norma ISO/IEC 27001:2022, te presento algunas fuentes de información y actualización relevantes, incluyendo sitios web, blogs, publicaciones, conferencias y redes profesionales.

Aquí hay algunas fuentes confiables y actualizadas para mantenerte al tanto de las últimas tendencias, noticias y mejores prácticas en seguridad de la información:

- Sitios Web de Noticias y Blogs:
 - The Hacker News
 - Krebs on Security
 - Dark Reading
 - Schneier on Security
 - CSO Online
 - Wired - Security
 - ZDNet - Security
 - The Register – Security
 - Incibe
- Publicaciones y Revistas Académicas:
 - Journal of Information Security and Applications
 - Computers & Security
- Organizaciones Profesionales y de Estándares:
 - International Information System Security Certification Consortium, or (ISC)²
 - Information Systems Audit and Control Association (ISACA)
 - SANS Institute
 - National Institute of Standards and Technology (NIST)
 - The International Organization for Standardization (ISO) - Particularly ISO/IEC 27001 for Information Security Management
- Boletines y Alertas de Seguridad:
 - US-CERT Alerts
 - SANS Newsletters

Estas son solo algunas de las muchas fuentes disponibles. Es importante mantenerse actualizado en esta área debido al rápido avance de las tecnologías y las tácticas cambiantes de los atacantes.

ANEXOS

ANEXO A – POLÍTICA DE SEGURIDAD DE LA INFORMACIÓN

POLÍTICA GENERAL DE SEGURIDAD DE LA INFORMACIÓN

[NUESTRA ORGANIZACIÓN] reconoce a la información, junto a los procesos y sistemas que hacen uso de ella, como un activo muy importante del que depende la empresa para su buen funcionamiento.

La **CONFIDENCIALIDAD**, **INTEGRIDAD** y **DISPONIBILIDAD** de información, pueden llegar a ser esencial para mantener los niveles de competitividad, rentabilidad, conformidad legal e imagen empresarial necesarios para lograr los objetivos de la Organización.

Y, atendiendo la importancia de mantener un alto estándar de Seguridad de la Información, **[NUESTRA ORGANIZACIÓN]**, asume la responsabilidad de implementar, mantener y mejorar continuamente un Sistema de Gestión de la Seguridad de la Información (SGSI) basado en la norma **ISO/IEC 27001:2022** que permita lograr niveles adecuados de seguridad para todos los activos de información de la Organización.

Así mismo, nos comprometemos a garantizar que los riesgos de la seguridad de la información sean conocidos, asumidos, gestionados y minimizados por la organización de una forma documentada, sistemática, estructurada, repetible, eficiente y adaptada a los cambios que se produzcan en los riesgos, el entorno y la tecnología.

Nuestra Política será revisada y actualizada periódicamente o cuando exista cambios significativos en el entorno operativo, legal o tecnológico.

La **[ALTA DIRECCIÓN]** de **[NUESTRA ORGANIZACIÓN]**, ha aprobado la ***Política General de Seguridad de la Información*** y, ha dispuesto los recursos y mecanismos necesarios para la adecuada implementación de esta, alineándose con los requisitos de la norma internacional **ISO/IEC 27001:2022** y la Legislación Vigente.

ANEXO B – DECLARACIÓN DE APLICABILIDAD

La declaración de aplicabilidad puede o no contener todos los controles del Anexo A de la norma ISO/IEC 27001:2022, sin embargo, esto dependerá de los riesgos relevados y del alcance definido para el SGSI.

Los controles del Anexo A de la norma ISO/IEC 27001:2022 se listan a continuación:

27001:2022	CONTROL	27001:2013	DESCRIPCIÓN 27002:2022
5.1	Políticas para la seguridad de la información	05.1.1, 05.1.2	La política de seguridad de la información y las políticas específicas del tema deben ser definidas, aprobadas por la gerencia, publicadas, comunicadas y reconocidas por el personal relevante y las partes interesadas relevantes, y revisadas a intervalos planificados y si ocurren cambios significativos.
5.2	Roles y responsabilidades de seguridad de la información	06.1.1	Los roles y responsabilidades de seguridad de la información deben definirse y asignarse de acuerdo con las necesidades de la organización.
5.3	Segregación de deberes	06.1.2	Deben segregarse los deberes conflictivos y las áreas conflictivas de responsabilidad.
5.4	Responsabilidades de gestión (la dirección)	07.2.1	La gerencia debe exigir a todo el personal que aplique la seguridad de la información de acuerdo con la política de seguridad de la información establecida, las políticas y los procedimientos específicos del tema de la organización.
5.5	Contacto con las autoridades	06.1.3	La organización debe establecer y mantener contacto con las autoridades pertinentes.
5.6	Contacto con grupos de interés especial	06.1.4	La organización debe establecer y mantener contacto con grupos de interés especial u otros foros especializados en seguridad y asociaciones profesionales.
5.7	Inteligencia de amenazas	NUEVO CONTROL	La información relacionada con las amenazas a la seguridad de la información debe recopilarse y analizarse para generar información sobre amenazas.
5.8	Seguridad de la información en la gestión de proyectos	06.1.5, 14.1.1	La seguridad de la información debe integrarse en la gestión de proyectos.

5.9	Inventario de información y otros activos asociados	08.1.1, 08.1.2	Se debe desarrollar y mantener un inventario de información y otros activos asociados, incluidos los propietarios.
5.10	Uso aceptable de información y otros activos asociados	08.1.3, 08.2.3	Deben identificarse, documentarse e implementarse reglas para el uso aceptable y procedimientos para el manejo de la información y otros activos asociados.
5.11	Retorno de los activos	08.1.4	El personal y otras partes interesadas, según corresponda, deben devolver todos los activos de la organización que estén en su poder al cambiar o terminar su empleo, contrato o acuerdo.
5.12	Clasificación de información	08.2.1	La información debe clasificarse de acuerdo con las necesidades de seguridad de la información de la organización en función de la confidencialidad, la integridad, la disponibilidad y los requisitos pertinentes de las partes interesadas.
5.13	Etiquetado de información	08.2.2	Se debe desarrollar e implementar un conjunto apropiado de procedimientos para el etiquetado de la información de acuerdo con el esquema de clasificación de la información adoptado por la organización.
5.14	Transferencia de información	13.2.1, 13.2.2, 13.2.3	Deben existir reglas, procedimientos o acuerdos de transferencia de información para todos los tipos de instalaciones de transferencia dentro de la organización y entre la organización y otras partes.
5.15	Control de acceso	09.1.1, 09.1.2	Las reglas para controlar el acceso físico y lógico a la información y otros activos asociados deben establecerse e implementarse en función de los requisitos comerciales y de seguridad de la información.
5.16	Gestión de identidad	09.2.1	Debe gestionarse el ciclo de vida completo de las identidades.
5.17	Información de autenticación	09.2.4, 09.3.1, 09.4.3	La asignación y gestión de la información de autenticación debe controlarse mediante un proceso de gestión, incluido el asesoramiento al personal sobre el manejo adecuado de la información de autenticación.
5.18	Derechos de acceso	09.2.2, 09.2.5,	Los derechos de acceso a la información y otros activos asociados deben

		09.2.6	proporcionarse, revisarse, modificarse y eliminarse de acuerdo con la política y las reglas de control de acceso específicas del tema de la organización.
5.19	Seguridad de la información en las relaciones con los proveedores	15.1.1	Deben definirse e implementarse procesos y procedimientos para gestionar los riesgos de seguridad de la información asociados con el uso de los productos o servicios del proveedor.
5.20	Abordar la seguridad de la información dentro de los acuerdos de proveedores	15.1.2	Los requisitos de seguridad de la información pertinentes deben establecerse y acordarse con cada proveedor en función del tipo de relación con el proveedor.
5.21	Gestión de la seguridad de la información en la cadena de suministro de las TIC	15.1.3	Deben definirse e implementarse procesos y procedimientos para gestionar los riesgos de seguridad de la información asociados con la cadena de suministro de productos y servicios de TIC.
5.22	Monitoreo, revisión y gestión de cambios de servicios de proveedores	15.2.1, 15.2.2	La organización debe monitorear, revisar, evaluar y gestionar periódicamente los cambios en las prácticas de seguridad de la información del proveedor y la prestación de servicios.
5.23	Seguridad de la información para el uso de servicios en la nube	NUEVO CONTROL	Los procesos de adquisición, uso, gestión y salida de los servicios en la nube deben establecerse de acuerdo con los requisitos de seguridad de la información de la organización.
5.24	Gestión de incidentes de seguridad de la información Planificación y preparación	16.1.1	La organización debe planificar y prepararse para la gestión de incidentes de seguridad de la información definiendo, estableciendo y comunicando procesos, funciones y responsabilidades de gestión de incidentes de seguridad de la información.
5.25	Evaluación y decisión sobre eventos de seguridad de la información	16.1.4	La organización debería evaluar los eventos de seguridad de la información y decidir si se clasificarán como incidentes de seguridad de la información.
5.26	Respuesta a incidentes de seguridad de la información	16.1.5	Se debe responder a los incidentes de seguridad de la información de acuerdo con los procedimientos documentados.
5.27	Aprender de los incidentes de seguridad de la información	16.1.6	El conocimiento obtenido de los incidentes de seguridad de la información debe utilizarse para fortalecer y mejorar los controles de seguridad de la información.

5.28	Recopilación de evidencia	16.1.7	La organización debe establecer e implementar procedimientos para la identificación, recopilación, adquisición y preservación de evidencia relacionada con eventos de seguridad de la información.
5.29	Seguridad de la información durante eventos disruptivos	17.1.1, 17.1.2, 17.1.3	La organización debe planificar cómo mantener la seguridad de la información en un nivel adecuado durante la interrupción.
5.30	Preparación para las TIC para la continuidad del negocio	NUEVO CONTROL	La preparación de las TIC debe planificarse, implementarse, mantenerse y probarse en función de los objetivos de continuidad del negocio y los requisitos de continuidad de las TIC.
5.31	Requisitos legales, legales, regulatorios y contractuales	18.1.1, 18.1.5	Los requisitos legales, estatutarios, reglamentarios y contractuales relevantes para la seguridad de la información y el enfoque de la organización para cumplir con estos requisitos deben identificarse, documentarse y mantenerse actualizados.
5.32	Derechos de propiedad intelectual	18.1.2	La organización debe implementar procedimientos apropiados para proteger los derechos de propiedad intelectual.
5.33	Protección de registros	18.1.3	Los registros deben protegerse contra pérdida, destrucción, falsificación, acceso no autorizado y publicación no autorizada.
5.34	Privacidad y protección de PII	18.1.4	La organización debe identificar y cumplir los requisitos relacionados con la preservación de la privacidad y la protección de la PII de acuerdo con las leyes y reglamentos aplicables y los requisitos contractuales.
5.35	Revisión independiente de la seguridad de la información	18.2.1	El enfoque de la organización para gestionar la seguridad de la información y su implementación, incluidas las personas, los procesos y las tecnologías, debe revisarse de forma independiente a intervalos planificados o cuando se produzcan cambios significativos.
5.36	Cumplimiento de las políticas, reglas y estándares para la seguridad de la información	18.2.2, 18.2.3	El cumplimiento de la política de seguridad de la información de la organización, las políticas específicas del tema, las reglas y los estándares debe revisarse periódicamente.
5.37	Procedimientos operativos documentados	12.1.1	Los procedimientos operativos para las instalaciones de procesamiento de información deben documentarse y

			ponerse a disposición del personal que los necesite.
--	--	--	--

Tabla 9: ISO/IEC 27002:2022 – Tema Organización

27001:2022	CONTROL	27001:2013	DESCRIPCIÓN 27002:2022
6.1	Selección	07.1.1	Los controles de verificación de antecedentes de todos los candidatos para convertirse en personal deben llevarse a cabo antes de unirse a la organización y de manera continua, teniendo en cuenta las leyes, regulaciones y ética aplicables, y deben ser proporcionales a los requisitos comerciales, la clasificación de la información a la que se accede y los riesgos percibidos.
6.2	Términos y condiciones de empleo	07.1.2	Los acuerdos contractuales de empleo deben establecer las responsabilidades del personal y de la organización para la seguridad de la información.
6.3	Conciencia de seguridad, educación y capacitación de la información	07.2.2	El personal de la organización y las partes interesadas relevantes deben recibir la conciencia, educación y capacitación adecuadas sobre la seguridad de la información y actualizaciones regulares de la política de seguridad de la información de la organización, las políticas y los procedimientos específicos del tema, según sea relevante para su función laboral.
6.4	Proceso Disciplinario	07.2.3	Se debe formalizar y comunicar un proceso disciplinario para tomar acciones contra el personal y otras partes interesadas relevantes que hayan cometido una violación de la política de seguridad de la información.
6.5	Responsabilidades después de la terminación o cambio de empleo	07.3.1	Las responsabilidades y deberes de seguridad de la información que siguen siendo válidos después de la terminación o el cambio de empleo deben definirse, aplicarse y comunicarse al personal pertinente y otras partes interesadas.
6.6	Acuerdos de confidencialidad o no divulgación	13.2.4	Los acuerdos de confidencialidad o no divulgación que reflejen las necesidades de la organización para la protección de la información deben ser identificados, documentados, revisados regularmente y

			firmados por el personal y otras partes interesadas relevantes.
6.7	Trabajo remoto	06.2.2	Se deben implementar medidas de seguridad cuando el personal trabaja de forma remota para proteger la información a la que se accede, procesa o almacena fuera de las instalaciones de la organización.
6.8	Informes de eventos de seguridad de la información	16.1.2, 16.1.3	La organización debe proporcionar un mecanismo para que el personal informe eventos de seguridad de la información observados o sospechados a través de los canales apropiados de manera oportuna.

Tabla 10: ISO/IEC 27002:2022 – Tema Personas

27001:2022	CONTROL	27001:2013	DESCRIPCIÓN 27002:2022
7.1	Perímetros de seguridad física	11.1.1	Los perímetros de seguridad deben definirse y utilizarse para proteger las áreas que contienen información y otros activos asociados.
7.2	Entrada física	11.1.2, 11.1.6	Las áreas seguras deben estar protegidas por controles de entrada y puntos de acceso apropiados.
7.3	Asegurar oficinas, habitaciones e instalaciones	11.1.3	Debe diseñarse e implementarse la seguridad física de las oficinas, salas e instalaciones.
7.4	Monitoreo de seguridad física	NUEVO CONTROL	Las instalaciones deben ser monitoreadas continuamente para detectar accesos físicos no autorizados.
7.5	Protección contra amenazas físicas y ambientales	11.1.4	Se debe diseñar e implementar la protección contra amenazas físicas y ambientales, como desastres naturales y otras amenazas físicas intencionales o no intencionales a la infraestructura.
7.6	Trabajando en áreas seguras	11.1.5	Se deben diseñar e implementar medidas de seguridad para trabajar en áreas seguras.
7.7	Descripción de la pantalla y pantalla clara	11.2.9	Deben definirse y aplicarse adecuadamente reglas de escritorio limpio para documentos y medios de almacenamiento extraíbles y reglas de pantalla limpia para las instalaciones de procesamiento de información.
7.8	Manejo de equipos y protección	11.2.1	El equipo debe estar ubicado de forma segura y protegida.

7.9	Seguridad de activos fuera de las instalaciones	11.2.6	Los activos fuera del sitio deben estar protegidos.
7.10	Medios de almacenamiento	08.3.1, 08.3.2, 08.3.3, 11.2.5	Los medios de almacenamiento deben gestionarse a lo largo de su ciclo de vida de adquisición, uso, transporte y eliminación de acuerdo con el esquema de clasificación y los requisitos de manipulación de la organización.
7.11	Soporte de servicios públicos	11.2.2	Los equipos se deben proteger contra fallas de energía y otras interrupciones causadas por fallas en los servicios de suministro.
7.12	Cableado de seguridad	11.2.3	Los cables que transportan energía, datos o servicios de información de apoyo deben protegerse contra interceptaciones, interferencias o daños.
7.13	Mantenimiento de equipo	11.2.4	El equipo debe mantenerse correctamente para garantizar la disponibilidad, integridad y confidencialidad de la información.
7.14	Eliminación o reutilización segura del equipo	11.2.7	Los elementos del equipo que contengan medios de almacenamiento deben verificarse para garantizar que todos los datos confidenciales y el software con licencia se hayan eliminado o sobrescrito de forma segura antes de su eliminación o reutilización.

Tabla 11: ISO/IEC 27002:2022 – Tema Seguridad Física

27001:2022	CONTROL	27001:2013	DESCRIPCIÓN 27002:2022
8.1	Dispositivos de punto final del usuario	06.2.1, 11.2.8	La información almacenada, procesada o accesible a través de los dispositivos finales de los usuarios debe protegerse.
8.2	Derechos de acceso privilegiados	09.2.3	La asignación y el uso de derechos de acceso privilegiado deben restringirse y gestionarse.
8.3	Restricción de acceso a la información	09.4.1	El acceso a la información y otros activos asociados debe estar restringido de acuerdo con la política específica del tema establecida sobre control de acceso.
8.4	Acceso al código fuente	09.4.5	El acceso de lectura y escritura al código fuente, las herramientas de desarrollo y

			las bibliotecas de software debe administrarse adecuadamente.
8.5	Autenticación segura	09.4.2	Las tecnologías y los procedimientos de autenticación segura deben implementarse en función de las restricciones de acceso a la información y la política específica del tema sobre el control de acceso.
8.6	Gestión de capacidad	12.1.3	El uso de los recursos debe monitorearse y ajustarse de acuerdo con los requisitos de capacidad actuales y esperados.
8.7	Protección contra malware	12.2.1	La protección contra el malware debe implementarse y respaldarse mediante la conciencia adecuada del usuario.
8.8	Gestión de vulnerabilidades técnicas	12.6.1, 18.2.3	Se debe obtener información sobre las vulnerabilidades técnicas de los sistemas de información en uso, se debe evaluar la exposición de la organización a tales vulnerabilidades y se deben tomar las medidas apropiadas.
8.9	Gestión de configuración	NUEVO CONTROL	Las configuraciones, incluidas las configuraciones de seguridad, de hardware, software, servicios y redes deben establecerse, documentarse, implementarse, monitorearse y revisarse.
8.10	Eliminación de información	NUEVO CONTROL	La información almacenada en sistemas de información, dispositivos o en cualquier otro medio de almacenamiento debe ser eliminada cuando ya no sea necesaria.
8.11	Enmascaramiento de datos	NUEVO CONTROL	El enmascaramiento de datos se debe utilizar de acuerdo con la política específica del tema de la organización sobre el control de acceso y otras políticas relacionadas con el tema específico, y los requisitos comerciales, teniendo en cuenta la legislación aplicable.
8.12	Prevención de fugas de datos	NUEVO CONTROL	Las medidas de prevención de fuga de datos deben aplicarse a los sistemas, redes y cualquier otro dispositivo que procese, almacene o transmita información confidencial.
8.13	Copia de seguridad de la información	12.3.1	Las copias de respaldo de la información, el software y los sistemas deben mantenerse y probarse regularmente de acuerdo con la política de respaldo específica del tema acordada.

8.14	Redundancia de instalaciones de procesamiento de información	17.2.1	Las instalaciones de procesamiento de información deben implementarse con suficiente redundancia para cumplir con los requisitos de disponibilidad.
8.15	Registro	12.4.1, 12.4.2, 12.4.3	Se deben producir, almacenar, proteger y analizar registros que registren actividades, excepciones, fallas y otros eventos relevantes.
8.16	Actividades de monitoreo	NUEVO CONTROL	Las redes, los sistemas y las aplicaciones deben monitorearse para detectar comportamientos anómalos y deben tomarse las medidas apropiadas para evaluar posibles incidentes de seguridad de la información.
8.17	Sincronización de reloj	12.4.4	Los relojes de los sistemas de procesamiento de información utilizados por la organización deben sincronizarse con las fuentes de tiempo aprobadas.
8.18	Uso de programas de utilidad privilegiados	09.4.4	El uso de programas de utilidad que puedan anular los controles del sistema y de las aplicaciones debe restringirse y controlarse estrictamente.
8.19	Instalación de software en sistemas operativos	12.5.1, 12.6.2	Deben implementarse procedimientos y medidas para gestionar de forma segura la instalación de software en los sistemas operativos.
8.20	Seguridad de las redes	13.1.1	Las redes y los dispositivos de red deben protegerse, administrarse y controlarse para proteger la información en los sistemas y aplicaciones.
8.21	Seguridad de los servicios de red	13.1.2	Los mecanismos de seguridad, los niveles de servicio y los requisitos de servicio de los servicios de red deben identificarse, implementarse y monitorearse.
8.22	Segregación de redes	13.1.3	Los grupos de servicios de información, usuarios y sistemas de información deben estar segregados en las redes de la organización.
8.23	Filtrado web	NUEVO CONTROL	El acceso a sitios web externos debe administrarse para reducir la exposición a contenido malicioso.
8.24	Uso de la criptografía	10.1.1, 10.1.2	Deben definirse e implementarse reglas para el uso eficaz de la criptografía, incluida la gestión de claves criptográficas.
8.25	Ciclo de vida de desarrollo seguro	14.2.1	Deben establecerse y aplicarse reglas para el desarrollo seguro de software y

			sistemas.
8.26	Requisitos de seguridad de la aplicación	14.1.2, 14.1.3	Los requisitos de seguridad de la información deben identificarse, especificarse y aprobarse al desarrollar o adquirir aplicaciones.
8.27	Principios de arquitectura e ingeniería de sistema seguro	14.2.5	Los principios para diseñar sistemas seguros deben establecerse, documentarse, mantenerse y aplicarse a cualquier actividad de desarrollo de sistemas de información.
8.28	Codificación segura	NUEVO CONTROL	Los principios de codificación segura deben aplicarse al desarrollo de software.
8.29	Pruebas de seguridad en desarrollo y aceptación	14.2.8, 14.2.9	Los procesos de prueba de seguridad deben definirse e implementarse en el ciclo de vida del desarrollo.
8.30	Desarrollo subcontratado	14.2.7	La organización debe dirigir, monitorear y revisar las actividades relacionadas con el desarrollo de sistemas subcontratados.
8.31	Separación de entornos de desarrollo, prueba y producción	12.1.4, 14.2.6	Los entornos de desarrollo, prueba y producción deben estar separados y protegidos.
8.32	Gestión del cambio	12.1.2, 14.2.2, 14.2.3, 14.2.4	Los cambios en las instalaciones de procesamiento de información y los sistemas de información deben estar sujetos a procedimientos de gestión de cambios.
8.33	Información de prueba	14.3.1	La información de las pruebas debe seleccionarse, protegerse y gestionarse adecuadamente.
8.34	Protección de sistemas de información durante las pruebas de auditoría	12.7.1	Las pruebas de auditoría y otras actividades de aseguramiento que involucren la evaluación de los sistemas operativos deben planificarse y acordarse entre el evaluador y la gerencia correspondiente.

Tabla 12: ISO/IEC 27002:2022 – Tema Tecnología

ANEXO C – GESTIÓN DE RIESGOS DE SEGURIDAD DE LA INFORMACIÓN

Identificación y clasificación de Activos

Los activos de información se clasificarán de acuerdo si son Primarios o de Apoyo. Los activos primarios proceden del mapa de procesos de la organización, mientras que los activos de apoyo, regularmente proceden de los inventarios de las áreas tecnológicas y de tthh.

Activos Primarios

ÁREA ORGANIZATIVA	PROCESO	DESCRIPCIÓN DEL PROCESO
TECNOLOGÍA	BASE DE DATOS	
	INFRAESTRUCTURA	
	DESARROLLO	
TTHH	SELECCIÓN	
	RELACIONES LABORALES	
	SEGURIDAD Y SALUD OCUPACIONAL	
	NOMINA	
COMERCIAL	VENTAS	
	POSTVENTA	
CONTABILIDAD	CUENTAS POR PAGAR	
	CUENTAS POR COBRAR	
	COMPRAS	

Tabla 13: Activos Primarios de Información

Activos de Apoyo

TIPO	ACTIVO	DESCRIPCIÓN DEL ACTIVO
Instalaciones [L]	Centro de procesamiento de datos	
	Oficinas principales	
Hardware [HW]	Servidor de Base (Host)	
	Computador Portátil	
	Computador de Escritorio	

Software [SW]	MS Windows Server 2016	
	MS Windows 10	
	SQL Server 2008	
	ESET Antivirus	
Datos [D]	Base de Datos	
	Backup de Bases de Datos	
Comunicaciones [COM]	Internet	
	Red Interna	
Equipamiento Auxiliar [AUX]	Sistema Eléctrico General	
	Aire Acondicionado	
	Sistema de Detección de incendios	
Personal [P]	Personas	
Soportes de información [M]	Discos Externos	
	Servidor de Archivos	

Tabla 14: Activos de Apoyo de Información

Identificación y selección de amenazas

A continuación, se resume el anexo C de la norma ISO/IEC 27002:2022:

TIPO DE AMENAZA	AMENAZA	ORIGEN
Daño Físico	Incendio	A, D, E
	Accidente importante	A, D, E
	Destrucción del equipo o los medios	A, D, E
	Daño físico Polvo, corrosión, congelamiento	A, D, E
Fenómenos climáticos	Fenómenos sísmicos	E
	Fenómenos meteorológicos	E
Pérdida de los servicios esenciales	Pérdida de suministro de energía	A, D, E

	Falla en el equipo de telecomunicaciones	A, D
Compromiso de la información	Fuga de Información	A, D
	Pérdida de Control de Acceso	A, D
	Diseño Inseguro	A, D
	Componentes vulnerables y obsoletos	A, D
	Fallas de Identificación y Autenticación	A, D
	Fallas en el monitoreo de seguridad	A, D
	Código malicioso	A, D
	Suplantación de Identidad	D
	Ataque a infraestructura crítica	D
	Hurto de medios o documentos	D
	Hurto de equipo	D
	Datos provenientes de fuentes no confiables	A, D
	Manipulación con software	A, D
Fallas técnicas	Mal funcionamiento del hardware	A, D
	Falla del equipo	A
	Saturación del sistema de información	A, D
	Mal funcionamiento del software	A
	Incumplimiento en el mantenimiento del sistema de información	A, D
Acciones no autorizadas	Uso no autorizado del equipo	D

	Uso de software falso o copiado	A, D
	Corrupción de datos	D
	Procesamiento ilegal de los datos	D
Compromiso de las funciones	Error en el uso	A
	Abuso de derechos	A, D
	Falsificación de derechos	D
	Negación de acciones	D
	Incumplimiento en la disponibilidad del personal	A, D, E

Tabla 15: Selección de Amenazas

Origen	
A	Accidentales
D	Deliberadas
E	Ambientales

Tabla 16: Origen de las Amenazas

Identificación de vulnerabilidades

Las vulnerabilidades son fallos o debilidades de los activos que pueden ser afectados por una amenaza. Para cada amenaza existe al menos una vulnerabilidad.

A continuación, se resume el anexo D de la norma ISO/IEC 27002:2022:

Tipo de Activo	AMENAZA	VULNERABILIDAD
Instalaciones [L]	Incendio	Falla en los sistema detectores de incendios
	Accidente Importante	Falta de procesos y procedimientos actualizados acorde a la necesidad
	Fenómenos sísmicos	Sitios ubicados sobre fallas tectónicas
	Mal funcionamiento del hardware	Falla en el sistema de suministro de agua o de aire acondicionado

	Pérdida de suministro de energía	Red energética inestable
	Hurto de equipo	Ausencia de protección física de la edificación, puertas y ventanas
Hardware [HW]	Incumplimiento en el mantenimiento del sistema de información	Mantenimiento insuficiente/instalación fallida de los medios de almacenamiento
	Destrucción del equipo o los medios	Ausencia de esquemas de reemplazo periódico
	Daño físico Polvo, corrosión, congelamiento	Susceptibilidad a la humedad, el polvo y la suciedad
	Pérdida de suministro de energía	Susceptibilidad a las variaciones de voltaje
	Fenómenos meteorológicos	Susceptibilidad a las variaciones de temperatura
	Hurto de medios o documentos	Almacenamiento sin protección
	Copia no controlada	Falta de cuidado en la disposición final
	Copia no controlada	Recuperación de medios reciclados o desechados
Software [SW]	Abuso de derechos	Ausencia o insuficiencia de pruebas de software
	Abuso de derechos	Defectos bien conocidos en el software
	Abuso de derechos	Disposición o reutilización de los medios de almacenamiento sin borrado adecuado
	Abuso de derechos	Ausencia de pistas de auditoria
	Abuso de derechos	Asignación errada de los derechos de acceso
	Error en el uso	Interfaz de usuario compleja
	Error en el uso	Ausencia de documentación
	Error en el uso	Configuración incorrecta de

		parámetros
	Falsificación de derechos	Tablas de contraseñas sin protección
	Falsificación de derechos	Gestión deficiente de las contraseñas
	Procesamiento ilegal de los datos	Habilitación de servicios innecesarios
	Mal funcionamiento del software	Software nuevo o inmaduro
	Mal funcionamiento del software	Ausencia de control de cambios eficaz
	Manipulación con software	Descarga y usos no controlados de software
	Manipulación con software	Ausencia de copias de respaldo
	Hurto de medios o documentos	Ausencia de protección física de la edificación, puertas y ventanas
Comunicaciones [COM]	Negación de acciones	Ausencia de pruebas de envío o recepción de mensajes
	Escucha encubierta	Tráfico sensible sin protección
	Falla en el equipo de telecomunicaciones	Punto único de falla
	Espionaje remoto	Arquitectura insegura de la red
	Espionaje remoto	Transferencia de contraseñas en claro
	Saturación del sistema de información	Gestión inadecuada de la red (Tolerancia a fallas en el enrutamiento)
Personal [P]	Incumplimiento en la disponibilidad del personal	Ausencia del personal
	Destrucción del equipo o los medios	Procedimientos inadecuados de contratación
	Error en el uso	Entrenamiento insuficiente en seguridad
	Error en el uso	Uso incorrecto de software y hardware
	Error en el uso	Falta de conciencia acerca de la seguridad

	Procesamiento ilegal de los datos	Ausencia de mecanismos de monitoreo
	Hurto de medios o documentos	Trabajo no supervisado del personal externo o de limpieza
	Uso no autorizado del equipo	Ausencia de políticas para el uso correcto de los medios de telecomunicaciones y mensajería
	Divulgación	Ausencia de Fidelidad a la Organización
Organización [ORG]	Abuso de derechos	Ausencia de procedimiento formal para el registro y retiro de usuarios
	Abuso de derechos	Ausencia de proceso formal para la revisión (supervisión) de los derechos de acceso
	Abuso de derechos	Ausencia de reportes de fallas en los registros de administradores y operadores
	Incumplimiento en el mantenimiento del sistema de información	Respuesta inadecuada de mantenimiento del servicio
	Incumplimiento en el mantenimiento del sistema de información	Ausencia de acuerdos de nivel de servicio, o insuficiencia en los mismos.

Tabla 17: Identificación de vulnerabilidades

Evaluación de Riesgo Inherente

Valoración de la Probabilidad

Consideraciones:

1. Por cada amenaza existe al menos una vulnerabilidad.
2. El valor de la probabilidad se evalúa en torno a la experiencia y conocimientos que se tenga del activo de información

ACTIVO	AMENAZA	VULNERABILIDAD	PROBABILIDAD
Centro De Procesamiento De Datos	Incendio	Falla en los sistemas detectores de incendios	Probable (4)
Oficinas Principales	Fenómenos sísmicos	Sitios ubicados sobre fallas tectónicas	Probable (4)
Servidores	Daño físico Polvo, corrosión, congelamiento	Susceptibilidad a la humedad, el polvo y la suciedad	Improbable (2)
Sistemas Operativos	Uso de software falso o copiado	Uso indiscriminado de software falso o copiado debido a la falta de licenciamiento	Casi Seguro (5)
Base de Datos	Copia no controlada	Falta de cuidado en la disposición final	Probable (4)
Personas	Uso no autorizado del equipo	Personal que usa equipos que no se le ha entregado formalmente para usos no corporativos	Probable (4)

Tabla 18: Selección de Amenazas

Valoración del Impacto

Consideraciones:

1. Se valora el impacto por cada activo.
2. La valoración, se basa en los niveles de Confidencialidad, Integridad y Disponibilidad, que el activo perdería, si se explotase una vulnerabilidad.
3. Generalmente, el promedio de estos valores se toma como el valor del Impacto.

ACTIVO	IMPACTO			
	[C] CONFIDENCIALIDAD	[I] INTEGRIDAD	[D] DISPONIBILIDAD	NIVEL DE IMPACTO
Centro De Procesamiento De Datos	1	5	5	MAYOR (4)
Oficinas Principales	1	5	4	MODERADO (3)
Servidores	2	5	5	MAYOR (4)
Sistemas Operativos	5	1	1	MAYOR (4)
Base de Datos	5	4	2	MAYOR (4)
Personas	5	4	2	MAYOR (4)

Tabla 19: Valoración de impacto

Evaluación del Riesgo Inherente

Consideraciones:

1. Generalmente, es aceptado que, para valorar el Riesgo Inherente o natural, se multiplique el valor de Probabilidad por el Impacto causado.
2. La norma ISO/IEC 27001:2022, no especifica ninguna fórmula de cálculo de Riesgos; por lo que, se puede adoptar las fórmulas que la metodología que se use para el cálculo del riesgo.

$$R_i = P \times I$$

Identificación y Valoración de controles existentes

Consideraciones:

1. Los controles pueden ser propios de cada organización y mitigar o reducir los riesgos del activo.
2. Los controles de la norma ISO/IEC 27002:2022 pueden y deben ser usados en función de la necesidad y de la declaración de aplicabilidad que hace la organización.
3. La ponderación de cada uno de los controles aplicados, depende de la metodología de análisis de Riesgos que la organización haya adoptado.

ACTIVO	DESCRIPCIÓN DEL CONTROL	Aplicado	Frecuente	Responsable	Preventivo	Documentado
Centro De Procesamiento De Datos	8.14 Redundancia de instalaciones de procesamiento de información	3	5	4	5	3
Oficinas Principales	7.1 Perímetros de seguridad física	4	4	5	5	5

Servidores	8.2 Derechos de acceso privilegiados	5	4	5	4	4
Sistemas Operativos	8.19 Instalación de software en sistemas operativos	5	5	5	5	4
Base de Datos	8.18 Uso de programas de utilidad privilegiados	3	4	5	5	3
Personas	8.3 Restricción de acceso a la información	5	5	3	4	2

Tabla 20: Valoración de Controles

Evaluación de la efectividad de los controles

Consideraciones:

1. Los controles son efectivos si ayudan a disminuir el Riesgo.
2. Las salvaguardas también contribuyen a disminuir o mitigar el Riesgo, por lo que es recomendable tomarlos en consideración a la hora de evaluar el Riesgo Residual.

ACTIVO	DESCRIPCIÓN DEL CONTROL	EFICACIA DEL CONTROL	SALVAGUARDA
Centro De Procesamiento De Datos	8.14 Redundancia de instalaciones de procesamiento de información	4	Contrato con tercero
Oficinas Principales	7.1 Perímetros de seguridad física	4.6	Contrato con tercero
Servidores	8.2 Derechos de acceso privilegiados	4.4	
Sistemas Operativos	8.19 Instalación de software en sistemas operativos	4.8	
Base de Datos	8.18 Uso de programas de utilidad privilegiados	4	
Personas	8.3 Restricción de acceso a la información	4.6	

Tabla 21: Efectividad de los Controles

Evaluación y calificación de Riesgo Residual

Consideraciones:

- 1. El Riesgo Residual, es el Riesgo que queda luego de haber aplicado controles.
- 2. Este puede afectarse por el valor de la eficiencia de los controles y por la existencia o eficiencia que puedan suponer las salvaguardas.

ACTIVO	RIESGO	CALIFICACIÓN DEL RIESGO		EVALUACIÓN DEL RIESGO	
		PROBABILIDAD	IMPACTO	ZONA DE RIESGO	OPCIONES DE MANEJO DEL RIESGO
Centro De Procesamiento De Datos	Incendio	Raro (1)	Catastrófico (5)	MODERADA	Asumir el Riesgo Reducir el Riesgo
Oficinas Principales	Fenómenos sísmicos	Improbable (2)	Moderado (3)	MODERADA	Asumir el Riesgo Reducir el Riesgo
Servidores	Daño físico Polvo, corrosión, congelamiento	Raro (1)	Insignificante (1)	BAJA	Asumir el Riesgo
Sistemas Operativos	Uso de software falso o copiado	Posible (3)	Menor (2)	ALTA	Reducir el Riesgo Evitar el Riesgo Compartir o Transferir el Riesgo
Base de Datos	Copia no controlada	Improbable (2)	Moderado (3)	MODERADA	Asumir el Riesgo Reducir el Riesgo
Personas	Uso no autorizado del equipo	Improbable (2)	Menor (2)	MODERADA	Asumir el Riesgo Reducir el Riesgo

Tabla 22: Calificación del Riesgo Residual

ANEXO D – PLAN DE TRATAMIENTO DE RIESGOS

Consideraciones:

1. Tanto los objetivos de Seguridad de la Información, como los Riesgos Residuales no tolerados, deben ser tratados.
2. Cada Riesgo tiene un responsable, por lo que la ejecución de los planes de tratamiento, deben ser consensuados entre el equipo implementador del SGSI y el responsable del riesgo.
3. Se puede incluir en este tratamiento a las NO conformidades encontradas en las Auditorías de segunda y tercera partes.

ACTIVO	RIESGOS	CONTROLES	MÉTRICA	RESPONSABLE
Centro de procesamiento de datos	Incendio	8.14 Redundancia de instalaciones de procesamiento de información	Plan de capacitación a personal crítico en cada competencia asignada.	Jefe TI
Oficinas principales	Fenómenos sísmicos	7.1 Perímetros de seguridad física	Capacitaciones sobre técnicas de evacuación y primeros auxilios	Jefe TTHH
Sistemas Operativos	Copia no controlada	8.2 Derechos de acceso privilegiados	Política y/o Manual	Jefe de Infraestructura
Personas	Uso no autorizado del equipo	8.5 Autenticación segura	Tipos de Usuario y privilegios / Cantidad de usuarios privilegiados	Jefe de Seguridad de la Información

Tabla 23: Tratamiento de Riesgos

ANEXO E - OBJETIVOS DE SEGURIDAD DE LA INFORMACIÓN

Consideraciones:

1. Los objetivos de Seguridad de la Información son indispensables, a la hora de implementar un SGSI. Estos indicarán el norte hacia donde la organización quiere avanzar y ayudará a determinar que recursos se necesitarán para su consecución.
2. Si es primera vez que una organización implementa un SGSI, lo ideal, es que marque como objetivos principales la mejora de la cultura organizacional, la implementación de una metodología de riesgos, la mejora continua, la gestión de activos, etc. es decir, objetivos "fáciles de cumplir". Con ello, ya para la primera visita de seguimiento, la organización podría mantener o cambiar los objetivos con algo mas complicado de lograr, por ejemplo: un sitio alterno de datos o la consecución de un plan de recuperación de desastres.
3. Todos los objetivos deben cumplir al menos con las siguientes características:
 - a. Son coherentes con la Política de SI.
 - b. Son medibles.
 - c. Tienen en cuenta el contexto de la organización.
 - d. Tienen en cuenta los resultados de la evaluación y tratamiento de riesgos.
 - e. Tienen al menos un responsable asignado.
 - f. Son comunicados a las partes interesadas.
 - g. Pueden ser actualizados cuando el contexto cambie o cuando el riesgo desaparezca o disminuya.

A continuación, se presentan objetivos modelo de SI:

- Analizar y gestionar los riesgos de seguridad de la Información de manera eficiente.
- Concientizar y sensibilizar a los colaboradores sobre la necesidad e importancia del Sistema de Gestión de Seguridad de la Información.

- Mantener un proceso de mejora continua del Sistema de Gestión de Seguridad de la Información.
- Demostrar Compromiso en la mejora continua del Sistema de Gestión de Seguridad de la Información.

ANEXO F – POLÍTICA DE GESTIÓN DE ACCESO

GESTIÓN DE ACCESO

Política de Control de Acceso

- Los colaboradores sólo podrán acceder a gestionar aquella información para la que están expresamente autorizados.
- Se identificarán todos los requisitos de seguridad de las aplicaciones propias y de terceros, bases de datos, sistemas, equipos de procesamiento de Información, etc. y de acuerdo con su criticidad se implementará el control de acceso respectivo.
- Se establecerán controles de acceso a nivel de red, Sistema Operativo, de Aplicaciones y de Servicios.
- Se definirá claramente a los autorizadores de los permisos de acceso a la Información.
- No está permitido instalar software no autorizado, en los equipos de cómputo o de procesamiento de Información.
- Las credenciales de usuario serán válidas durante 90 días, después del último inicio de sesión en la plataforma.

Autorizadores de Acceso

La organización define que Accesos están disponibles para cada usuario y, que privilegios se otorgan. Es importante identificar qué nivel de acceso se puede Autorizar y, quienes son los Autorizadores del Acceso.

ACCESO	PRIVILEGIOS	NIVEL DE ACCESO	AUTORIZA
RED CORPORATIVA	Acceso a la Red Tecnológica	Usuario / Administrador	Jefe de Infraestructura / Jefe de TI

ENLACES VPN – RED CORPORATIVA	Acceso a parte de la Red Tecnológica	Usuario con acceso limitado	Jefe de TI
--------------------------------------	--------------------------------------	-----------------------------	------------

Tabla 24: Autorizadores de Acceso

Registro y cancelación de usuarios

- Se requerirá una solicitud de accesos de los usuarios tanto internos como externos, que contemple, a más de los roles solicitados, la firma de responsabilidad del solicitante.
- Se otorgarán accesos a los recursos de la organización, siempre utilizando el *Principio de Mínimo Privilegio*.
- Previa solicitud del área pertinente se podrá Modificar o Eliminar los accesos de los usuarios a los Sistemas de Información.
- Se suspenderán temporalmente los accesos de los usuarios en caso de vacaciones, comisiones, licencias y permisos temporales.
- La gestión de accesos privilegiados debe ser solicitados al Jefe de TI, este, luego de un análisis, autorizará o no el acceso.

Revisión de los derechos de acceso de usuario

- El departamento de Seguridad de la Información o de Infraestructura, según sea el caso, podrán revisar los derechos de acceso asignados, de todos los usuarios de todos los sistemas o plataformas de la Organización en cuanto lo consideren oportuno.

Retiro o ajuste de los derechos de acceso

- Se deben retirar los derechos de acceso a la información y a las instalaciones del procesamiento de información para todos los colaboradores, proveedores o usuarios de terceros, a la finalización de la relación laboral, contrato o acuerdo, o ser revisados en caso de cambio.
- Al momento del cese de labores de un funcionario del área TI se deberán modificar todas las contraseñas de los equipos de producción y, accesos remotos a los que excolaborador hubiese tenido acceso.

Uso de la Información de Autenticación Secreta

- Las credenciales de acceso son responsabilidad exclusiva del usuario.

- No está permitido, bajo ningún concepto, compartir contraseñas.
- La contraseña deberá ser cambiada al primer inicio de sesión.
- Para el Acceso a la Plataforma Corporativa, se entregarán las credenciales otorgadas en sobre cerrado de manera personal e intransferible.
- Se configurarán los sistemas correspondientes para que los usuarios cambien la contraseña con regularidad.

Restricción de acceso a la Información

- Se identificará a equipos sensibles, sistemas y aplicaciones propias de la Empresa y a sus administradores.
- Se identificará y documentarán equipos y sistemas sensibles que comparten recursos.
- Se deberá controlar el acceso a los sistemas y aplicaciones propias de la Empresa.
- Se deberá definir y controlar los derechos de acceso de usuarios, para lectura, escritura, eliminación y ejecución de información.

Procedimiento de Ingreso Seguro

- Recomendar la generación de contraseñas con letras mayúsculas, minúsculas, con caracteres especiales.
- Controlar el cambio periódico de contraseñas de los usuarios.
- Realizar y documentar revisiones periódicas de la gestión de usuarios incluyendo administradores.

ANEXO G – CLASIFICACIÓN DE LA INFORMACIÓN

Para la Clasificación de la información dentro de la Organización, debe considere la legislación aplicable con relación a la Protección de Datos Personales. En general esta normativa determina los siguientes tipos de datos:

TIPO DE DATO	DESCRIPCIÓN	SENSIBLE
Datos de identificación	Cualquier información que permita identificar a una persona, como el nombre completo, número de cédula, dirección, teléfono, correo electrónico, entre otros.	NO
Datos sensibles	Datos personales que requieren protección especial debido a su naturaleza, como la raza, orientación sexual, creencias religiosas, estado de salud, antecedentes penales, entre otros.	SI
Datos financieros	Información relacionada con la situación financiera de una persona, como ingresos, gastos, deudas, cuentas bancarias, tarjetas de crédito, entre otros.	NO
Datos laborales	Información relacionada con el empleo de una persona, como el cargo que desempeña, sueldo, horario de trabajo, entre otros.	NO
Datos académicos	Información relacionada con la educación de una persona, como el nivel de estudios, institución educativa, títulos obtenidos, entre otros.	NO
Datos de salud	Información relacionada con la salud de una persona, como el historial médico, enfermedades, alergias, medicamentos recetados, entre otros.	SI
Datos de geolocalización	Información sobre la ubicación física de una persona, ya sea en tiempo real o histórica.	NO

Tabla 25: Clasificación de la Información

Criterios de Clasificación de la Información:

CLASIFICACIÓN DE LA INFORMACIÓN	DESCRIPCIÓN
Pública	Se refiere a <i>información que puede ser divulgada al público sin restricciones</i> . Esta información contiene datos personales no sensibles ni información crítica de la organización.
Interna	Se refiere a <i>información que se utiliza internamente y se restringe su acceso a personas autorizadas</i> . Esta información puede contener datos personales no sensibles y otra información relevante para la organización, pero no es crítica para la operación.

Confidencial	Se refiere a <i>información que es crítica para la organización</i> y debe ser protegida adecuadamente para evitar su divulgación no autorizada. Esta información puede contener datos personales sensibles, secretos comerciales, propiedad intelectual , entre otros.
Crítica	Se refiere a <i>información que es crítica para la organización y que, si se divulga sin autorización, podría tener consecuencias graves para la misma</i> . Esta información puede incluir datos personales sensibles, información financiera, estrategias corporativas , entre otros.

Tabla 26: Criterios de clasificación de la información

Etiquetado de la Información

Para el etiquetado de la información se considerará lo siguiente:

- La información generada bajo la Clasificación de Pública e Interna, no deberá ser etiquetado.
- Toda información generada por la organización bajo la Clasificación de Confidencial y Crítica, deberá ser etiquetada antes de ser almacenada, transmitida o compartida con terceros.
- El responsable de la información deberá asignar la clasificación correspondiente a cada documento de acuerdo con los criterios establecidos en esta política.
- El etiquetado puede llevarse a cabo mediante avisos de confidencialidad en correos electrónicos o encabezados o marcas de agua en documentos.
- Se deberán establecer controles de acceso y seguridad adecuados para cada nivel de clasificación de la información.
- La clasificación de la información deberá ser revisada periódicamente para garantizar que se mantenga actualizada y adecuada a la naturaleza de la información.

ANEXO H – GESTIÓN DE INCIDENTES DE SI

Evaluación y decisión sobre los eventos de seguridad de información

Se deberá evaluar el tipo de evento o incidente que se presenta, a que activos está afectando, cual es alcance de este, que pronóstico tiene de expansión, así

como los daños potenciales o reales que se generen. Para ello, se tomará en consideración el impacto y la urgencia de resolución.

El impacto del evento o incidente puede ser:

- **Alto Impacto:** El incidente de seguridad afecta a activos de información considerados de impacto catastrófico que influyen directamente en el negocio. Estos incidentes deben tener respuesta inmediata.
- **Medio Impacto:** El incidente de seguridad afecta a activos de información considerados de impacto moderado que influyen directamente en un proceso determinado.
- **Bajo Impacto:** El incidente de seguridad afecta a activos de información considerados de impacto menor. Estos incidentes deben ser monitoreados con el fin de evitar un cambio en el impacto.

La Urgencia de resolución del evento o incidente puede ser:

- **Alta Urgencia:** Cuando el impacto es alto y afecta al negocio o a su reputación.
- **Media Urgencia:** el incidente de seguridad afecta una parte del negocio o la operación.
- **Baja Urgencia:** el evento o incidente no repercute en el negocio o en la operación.

IMPACTO URGENCIA	ALTO (3)	MEDIO (2)	BAJO (1)
ALTO (3)	9	6	3
MEDIO (2)	6	4	2
BAJO (1)	3	2	1

Tabla 27: Evaluación de Incidentes de SI

Respuesta a incidentes de seguridad de la información

Cuando un incidente se produzca, Ejecutivo de Seguridad de la Información o su delegado, conjuntamente con el colaborador responsable del equipo o sistema afectado deberán realizar las siguientes acciones en su orden:

- Identificar el tipo de incidente.
- Registrar el incidente en la bitácora de incidentes.

- Clasificar el incidente de acuerdo con el tipo de servicio afectado y al nivel de severidad (Criticidad).
- Asignar una prioridad de atención al incidente en el caso de que se produjeran varios en forma simultánea.
- Realizar un diagnóstico inicial, determinando mensajes de error producidos, identificando los eventos ejecutados antes de que el incidente ocurra, recreando el incidente para identificar sus posibles causas.
- Escalar el incidente en el caso que la solución del incidente deba ser solucionado por otras áreas (desarrollo, operaciones, producción, etc.), o proveedores de servicio.
- Investigar y diagnosticar en forma definitiva las causas por las cuales se produjo el incidente.
- Resolver y restaurar el servicio afectado por el incidente, incluyendo un registro de la solución empleada en la bitácora de incidentes.
- Cerrar el incidente, actualizando el estado del registro del incidente en la bitácora de incidentes a "Resuelto".
- Confirmar con el usuario, departamento o área afectada que el incidente ha sido resuelto.

ANEXO I – REVISIÓN POR LA DIRECCIÓN

Consideraciones:

1. La revisión por la Dirección no tiene un formato estándar; por lo que se propone un modelo que se puede utilizar a conveniencia.

Asunto: *Revisión por la Dirección del SGSI*
Destinatario: *Alta Dirección*
Remite: *[Oficial de Cumplimiento]*

Resumen Ejecutivo:

El Sistema de Gestión de Seguridad de la Información (SGSI) es fundamental para nuestra organización, tanto para proteger nuestros activos de información de amenazas y riesgos, como para cumplir con las necesidades y expectativas de nuestras partes interesadas. El SGSI establece controles para salvaguardar la confidencialidad, integridad y disponibilidad de la información que tratamos, permitiéndonos responder efectivamente a incidentes de seguridad y prevenir su recurrencia.

Al momento, hemos alcanzado un 70% de implementación de la norma ISO/IEC 27001:2022. Este logro es significativo, ya que hemos abordado y superado una serie de brechas identificadas en nuestro análisis gap inicial. Sin embargo, todavía tenemos trabajo por hacer. Necesitamos fortalecer nuestra formación en seguridad de la información, mejorar nuestros procesos de respaldo y recuperación de desastres, y asegurar una revisión más sistemática y frecuente de nuestras políticas y procedimientos. Al abordar estas áreas, nos acercaremos a nuestro objetivo final de lograr la conformidad total con la norma ISO/IEC 27001:2022.

1. Estado de las acciones de las revisiones de gestión anteriores

Desde la última revisión con la dirección a la fecha, hemos logrado importantes avances:

- **Análisis de Riesgos:** Hemos realizado un exhaustivo análisis de riesgos de la información, identificando y evaluando los riesgos potenciales para nuestra organización.
- **Políticas de Seguridad de la Información:** Hemos establecido y documentado nuestra política de seguridad de la información, las cuales se comunicaron a todos los miembros de la organización y se encuentran disponibles para su consulta.
- **Gestión de Activos:** Se han identificado los activos de información y, se ha asignado un propietario a cada uno de ellos. Todos los activos están clasificados y protegidos de acuerdo a su clasificación.

- **Control de Accesos:** Se han implementado políticas de control de acceso y se han establecido roles y responsabilidades.

2. Cambios en cuestiones externas e internas relevantes para el SGSI

No se han evidenciado cambios en las cuestiones internas y externas de la organización que afecten el desarrollo del SGSI. Sin embargo, se recomienda revisar el mapa de procesos de la organización.

3. Cambios en las necesidades y expectativas de las partes interesadas relevantes para el SGSI

No se han evidenciado cambios en las necesidades y expectativas de las partes interesadas de la organización que afecten el desarrollo del SGSI. Esto podría cambiar muy pronto, debido a que está en marcha un análisis FODA de la organización.

4. Rendimiento del SGSI:

- No conformidades y acciones correctivas:** En la última auditoría interna se identificaron varias no conformidades. Aunque las no conformidades son motivo de preocupación, se están tomando medidas proactivas para corregirlas y prevenir su reaparición.
- Resultados de monitoreo y medición:** Las medidas de monitoreo y medición implementadas han demostrado ser efectivas para detectar y prevenir incidentes de seguridad. Tal es así, que en el último mes, se detectaron de manera temprana dos incidentes de seguridad y fueron mitigados antes de que afectara seriamente a la organización.
- Resultados de auditorías:** La última auditoría interna reveló no conformidades, como se mencionó anteriormente. Esto indica la necesidad de mejorar ciertos aspectos del SGSI, pero también demuestra que nuestro proceso de auditoría es efectivo para identificar áreas de mejora.

- d. **Cumplimiento de los objetivos de seguridad de la información:** A pesar de las no conformidades identificadas, se está logrando el cumplimiento general de los objetivos de seguridad de la información. Los datos demuestran que los controles de seguridad implementados han tenido éxito en mantener la integridad, la disponibilidad y la confidencialidad de la información de la organización. Esto sugiere que, aunque existen áreas para mejorar, el SGSI en su conjunto está funcionando eficazmente para cumplir con sus objetivos.

5. Evaluación de riesgos y Plan de tratamiento de riesgos

A continuación, se muestra la matriz de riesgo residual de SI, donde se evidencia que no existen Riesgos críticos.

MATRIZ DE RIESGOS					
	IMPACTO				
PROBABILIDAD	1	2	3	4	5
RARO (1)	9	3	29	10	8
IMPROBABLE (2)	3	7	36	5	
POSIBLE (3)	3	17	5		
PROBABLE (4)					
CASI SEGURO (5)					

Tabla 28: Ejemplo – Matriz de Riesgos Residuales de SI

Adicionalmente, los riesgos considerados altos y, que requieren tratamiento, se establecen en la siguiente tabla:

ACTIVO	RIESGOS	CONTROLES	MÉTRICA	RESPONSABLE
Centro de procesamiento de datos	Incendio	8.14 Redundancia de instalaciones de procesamiento de información	Plan de capacitación a personal crítico en cada competencia asignada.	Jefe TI
Oficinas principales	Fenómenos sísmicos	7.1 Perímetros de seguridad física	Capacitaciones sobre técnicas de evacuación y primeros auxilios	Jefe TTHH
Sistemas Operativos	Copia no controlada	8.2 Derechos de acceso privilegiados	Política y/o Manual	Jefe de Infraestructura

Personas	Uso no autorizado del equipo	8.5 Autenticación segura	Tipos de Usuario y privilegios / Cantidad de usuarios privilegiados	Jefe de Seguridad de la Información
----------	------------------------------	--------------------------	---	-------------------------------------

Tabla 29: Ejemplo – Actividades de Tratamiento de Riesgos

6. Conclusiones

En general, estamos en el camino correcto para lograr la plena conformidad con la norma ISO/IEC 27001:2022 y, finalmente poder certificarnos como una entidad que cumple con los estándares de la norma internacional.

7. Recomendaciones

A pesar de nuestro sólido progreso, aún hay áreas en las que podemos mejorar:

- **Formación y Concienciación:** Es esencial seguir trabajando en la formación y la sensibilización de todos los empleados sobre la importancia de la seguridad de la información y cómo sus acciones pueden afectarla.
- **Auditoría Interna:** Sería beneficioso realizar una auditoría interna de nuestro sistema de gestión de seguridad de la información para prepararnos para la auditoría de certificación.

Agradezco su apoyo continuo mientras trabajamos para implementar la norma ISO/IEC 27001.

Atentamente,

[Oficial de cumplimiento]

[1] British Standard

[2] International Organization for Standardization / International Electrotechnical Commission

[3] A partir de la publicación de la versión 2022, los **Dominios**, pasan a denominarse **Temas**.

[4] Las normas ISO que terminan en 1 (uno) son certificables.

[5] Todos los objetivos que se planteen tienen que SMART (Específicos (Specific), Medibles (Measurable), Alcanzables (Achievable), Realistas (Realistic) y de Duración limitada (Time-bound)).

[6] Se deben considerar leyes aplicables, como por ejemplo regulaciones de protección de datos personales.

[7] Este catálogo no es absoluto. La organización puede y debe identificar amenazas adicionales que no se encuentren en el catálogo e incluirlas.

[8] Este catálogo no es absoluto. La organización puede y debe identificar amenazas adicionales que no se encuentren en el catálogo e incluirlas.

[9] Nota: La Tabla 6: Administración del Riesgo, propone un criterio de aceptación de Riesgo.

[10] Statement of Applicability

[11] Recomendación del autor.

[12] Actualmente, en el mercado existen plataformas gratuitas de formación y concienciación en seguridad de la información.

[13] Los puntos esenciales de la Política de Seguridad de la Información se tocaron en el acápite 3.1 del presente libro.

[14] En el acápite 4.1 del presente libro, se hace referencia a una metodología propuesta por el autor.

[15] Entiéndase, asignación de roles y responsabilidades.

[16] En el acápite 2.3 del presente libro, se hace referencia al ciclo PDCA (Planificar, Hacer, Verificar, Actuar), como un ciclo continuo.